ASSIGNMENT FINAL REPORT

Qualification	**Pearson BTEC Level 5 Higher National Diploma in Computing**		
Unit number and title	**Unit 16: Computing Research Project (Pearson-set)**		
Submission date	01/03/2026	**Date Received 1st submission**	
Re-submission Date		**Date Received 2nd submission**	
Student Name	Tran Tien Hung	**Student ID**	BH01626
Class	SE07202	**Assessor name**	Nguyen Thanh Trieu

Plagiarism

Plagiarism is a particular form of cheating. Plagiarism must be avoided at all costs and students who break the rules, however innocently, may be penalised. It is your responsibility to ensure that you understand correct referencing practices. As a university level student, you are expected to use appropriate references throughout and keep carefully detailed notes of all your sources of materials for material you have used in your work, including any material downloaded from the Internet. Please consult the relevant unit lecturer or your course tutor if you need any further advice.

Student Declaration

I certify that the assignment submission is entirely my own work and I fully understand the consequences of plagiarism. I declare that the work submitted for assessment has been carried out without assistance other than that which is acceptable according to the rules of the specification. I certify I have clearly referenced any sources and any artificial intelligence (AI) tools used in the work. I understand that making a false declaration is a form of malpractice.

Student's signature	Hung

Grading grid

P1	P2	P3	P4	P5	P6	P7	M1	M2	M3	M4	D1	D2	D3

☐ Summative Feedback:	☐ Resubmission Feedback:	
Grade:	**Assessor Signature:**	**Date:**
Internal Verifier's Comments:		
Signature & Date:		

Table of Contents

A. Introduction 7

B. Content 8

Part 1 8

I. Produce a research proposal that clearly defines a research question or hypothesis supported by a literature review. 8

1. Research Subject and Project Title 8

2. Executive Summary 8

3. Context, Rationale, and Problem Statement 9

4. Research Questions and Hypotheses 9

5. Project Objectives 10

6. Research Methodology 12

7. Implementation Roadmap & Milestones 12

II. Examine appropriate research methods and approaches to primary and secondary research. 14

1. Primary research 14

2. Secondary research 16

III. Conduct primary and secondary research using appropriate methods for a computing research project that consider costs, access and ethical issues. 18

1. Secondary research 18

2. Primary research 19

IV. Apply appropriate analytical tools, analyse research findings and data. 21

1. List of Interviewees and Their Relevance to the Project 21

2. List of Project-Related Questions 25

3. Statistics, Analysis, and Evaluation of the Obtained Results 27

4. Analysis of the Impact of the Results on the Project 41

V. Communicate research outcomes in an appropriate manner for the intended audience. 42

1. Cybersecurity Experts 42

2. Implementing Project Stakeholders 42

3. Future Users of the Project 43

VI. Analyze different research approaches and methodology and make justifications for the choice of methods selected based on philosophical/theoretical frameworks 43
1. Analysis of Different Research Methods....43
2. Justifications for the Choice of Research Methods 45
3. Philosophical/Theoretical Frameworks in Computing Research 45
VII. Discussion on Advantages, Limitations, and Risks of Data Collection and AnalysisMethods 47
1. Data Collection Methods 47
2. Data Analysis Methods 47
VIII. Analyse the extent to which outcomes meet set research objectives and communicate judgements effectively for the intended audience 50
1. Analyzing the Extent to Which Outcomes Meet Research Objectives 50
2. Communicating Judgements Effectively for the Intended Audience 51
IX. Critically evaluate research methods and processes in application to a computer research project to justify the chosen methods and analysis....55
1. Critical Evaluation and Methodology Creation....55
2. Critical Evaluation of Analytical Methods 57
3. Analytical Justification for the Selection of Research Methods 59
X: Evaluate outcomes and make valid, justified recommendations....61
1. Evaluation of Achieved Outcomes....61
2. Valid and Justified Recommendations for Future Architecture....63
C. Conclusion....75
D. References 76
E. Project Resources 77

List of Figure

Figure 1: High-level 3-Tier Architecture of the Secure SCMS 11
Figure 2: Primary research 14
Figure 3: Secondary research 16
Figure 4: Survey Result Q1 - Distribution of Participant Expertise.....29
Figure 5: Survey Result Q2 - Years of Experience in IT Industry.....29
Figure 6: Survey Result Q3 - Experience with Sensitive Data Systems 30
Figure 7: Survey Result Q4 - Perceived Risk Level of Insider Threats 31
Figure 8: Survey Result Q5 - Effectiveness of Native Encryption Against Privileged Users.....31
Figure 9: Survey Result Q6 - Prevalence of Causes in Data Breaches.....32
Figure 10: Survey Result Q7 - Agreement on Application-Layer Encryption for Zero Trust.....33
Figure 11: Survey Result Q8 - Suitability of Envelope Encryption for E-commerce.....34
Figure 12: Survey Result Q9 - Opinions on Hybrid Storage Strategy 34
Figure 13: Survey Result Q10 - Importance of Tamper Detection against DBAs.....35
Figure 14: Survey Result Q11 - Acceptability of KEK Storage in Environment Variables 36
Figure 15: Survey Result Q12 – Maximum Acceptable Latency for Security 37
Figure 16: Survey Result Q13 – Challenges in Implementing Application-Level Encryption.....37
Figure 17: Survey Result Q14 – Automated Response to Data Tampering.....38
Figure 18: Survey Result Q15 – Recommended Master Key Rotation Frequency.....39
Figure 19: Survey Result Q16 – Importance of Data Masking in Audit Logs 39
Figure 20: Survey Result Q18 – Main Barriers to Adopting Cloud KMS.....40
Figure 21: Application Sitemap and Navigation Structure – Demonstrating system logic and ease of use for non-technical stakeholders. 52
Figure 22: Simplified Encryption/Decryption Process Flowchart for Non-Technical Audiences 53
Figure 23: Sequence Diagram illustrating the AES-256-GCM encryption flow at the Middleware/Security Layer. 54
Figure 24: Hybrid Storage Database Schema distinguishing between Plaintext Metadata and AES-256 Ciphertext. 55

List of Table

Table 1: Briefly summarize the project implementation plan 13
Table 2: Implementation Roadmap & Milestones 14
Table 3: Secondary Documents and Data Collected 19
Table 4: List of Interview Subjects 22
Table 5: List of Survey Respondents 25
Table 6: Key Survey Questions 27
Table 7: Comparative Analysis of Primary and Secondary Research in the Project 44
Table 8: Comparative Analysis of Quantitative and Qualitative Approaches 44
Table 9: Integration of Quantitative and Qualitative Findings.....45
Table 10: Quantitative Outcomes.....51

A. Introduction

The exponential digitization of global logistics and retail ecosystems has centralized massive volumes of sensitive supply chain telemetry—ranging from consumer Personally Identifiable Information (PII) to wholesale vendor pricing algorithms—within high-availability database architectures. Historically, E-commerce cybersecurity has disproportionately focused on perimeter defense methodologies, relying heavily on Transport Layer Security (TLS/HTTPS) to secure data-in-transit while assuming internal database perimeters remain fundamentally secure. However, contemporary threat intelligence—as corroborated by the Open Worldwide Application Security Project (OWASP) and the National Institute of Standards and Technology (NIST)—indicates that perimeter defenses are critically failing against targeted lateral movement and "Insider Threats." Standard mechanisms such as Transparent Data Encryption (TDE) merely protect physical storage drives against hardware theft. They automatically decrypt data for authenticated Database Administrators (DBAs), leaving core operational payloads entirely transparent to any rogue administrator or sophisticated persistent threat that compromises a high-privileged database account. This exposes modern supply chains to devastating corporate espionage, untraceable data tampering, and catastrophic privacy breaches.

To actively eradicate this architectural vulnerability, this computing research project, titled "Encrypting Order Transaction Information for an E-commerce Program," engineers a deterministic Zero Trust paradigm. Instead of relying on the database engine for confidentiality, this project hypothesizes and formally evaluates the implementation of Application-Layer Envelope Encryption. By actively utilizing the AES-256-GCM (Advanced Encryption Standard in Galois/Counter Mode) authenticated cryptography embedded directly within the Node.js middleware, the system algorithmically guarantees that the relational database (SQL Server) acts strictly as a "blind storage" medium. The core rationale driving this research is to construct a system where the physical obfuscation of data prevents both unauthorized extraction and malicious bit-flipping (tampering), ensuring absolute mathematical integrity without requiring prohibitively expensive Hardware Security Modules (HSMs).

The overarching objective of this thesis is to architect, develop, and empirically stress-test the "Secure Supply Chain Management System" (SCMS)—a full-stack E-commerce prototype. Architecturally, the project aims to transition the conventional MERN-like stack into a hyper-secure Cryptographic Hierarchy by synthesizing a Master Key Encryption Key (KEK) to autonomously wrap individual Data Encryption Keys (DEKs) for routine supply transactions. Operationally, the research designs a pragmatic "Hybrid Storage" database schema intended to resolve the severe developer latency historically associated with encrypted database querying by selectively encrypting PII while retaining critical metadata in rapid indexing plaintext. To validate these designs, the project conducts rigorous quantitative load testing via JMeter alongside defensive unit testing, seeking to statistically prove that AES-GCM can enforce 100% anomaly detection while maintaining a user-experience latency overhead of strictly under 50 milliseconds per transacted payload.

To systemically justify the selected architectural and cryptographic modalities against BTEC computing standards, this final report is structured into distinct analytical modules. Applying a mixed-methods

research framework consisting of a 78-participant expert technical survey and qualitative logistics interviews, the document directly correlates theoretical cryptographic mathematics to human-centric developer friction and end-user digital anxiety. Iterating from foundational literature reviews and stringent threat modeling scenarios (STRIDE), the report details the exact execution methodologies behind the primary benchmarking data. Finally, a strict critical evaluation mathematically exposes the systemic outcomes, friction points, and future scalability constraints characterizing the deployment of this encrypted E-commerce prototype.

B. Content

Part 1

I. Produce a research proposal that clearly defines a research question or hypothesis supported by a literature review.

1. Research Subject and Project Title

- **Research Subject:** Cyber Security.
- **Project Title:** Safe warehouse management for e-commerce systems.

2. Executive Summary

This project investigates and constructs a robust, self-defending security subsystem designed to eliminate persistent "blind spots" within database management systems. The core innovation of this research is the conceptualization and deployment of Application-Layer Encryption (ALE) driven by an Envelope Encryption architecture, functioning independently of the underlying storage engine.

Unlike conventional static encryption schemes that utilize a singular, monolithic key for an entire database, this system creates a dynamic Cryptographic Key Hierarchy. It autonomously generates a unique, cryptographically secure Data Encryption Key (DEK) for *every individual transaction record* (e.g., a specific order or shipment). These transient DEKs are subsequently encrypted (wrapped) by a master Key Encryption Key (KEK) managed exclusively by the application server.

The project culminates in the synthesis of a full-stack E-commerce platform (utilizing React.js, Node.js, and SQL Server) where highly sensitive transaction primitives—such as supply costs, shipping coordinates, tracking identifiers, and Personally Identifiable Information (PII)—exist in a state of continuous ciphertext throughout their persistence lifecycle. Decryption occurs strictly within the volatile memory (RAM) of the application tier, triggered only upon successful validation of an authorized identity, thereby rendering the physical data storage functionally opaque to any unauthorized entity, including compromised root administrators.

3. Context, Rationale, and Problem Statement

3.1. The Fallacy of Perimeter Defense and Transparent Data Encryption (TDE)

Current E-commerce infrastructures exhibit a dangerous over-reliance on network perimeter defenses (Firewalls, WAFs) and Transport Layer Security (TLS/HTTPS). However, contemporary threat intelligence indicates that over 70% of catastrophic data breaches occur via compromised database credentials, SQL injection (SQLi), or insider threats. When an adversary gains lateral movement into the data tier, standard mitigation strategies like SQL Server's Transparent Data Encryption (TDE) fail completely. TDE encrypts data at rest on the disk, but decrypts it automatically for any authenticated database user. Thus, if the SQL service is compromised, the encryption is transparent to the attacker as well.

3.2. The Data Integrity and Tampering Crisis

Furthermore, legacy symmetric encryption algorithms (e.g., AES-CBC) utilized in older application-layer defenses provide confidentiality but lack authenticity. They are highly vulnerable to Ciphertext Modification Attacks (Bit-Flipping), wherein an attacker can predictably alter the encrypted value (e.g., manipulating an order's total_value from $1000 to $1) without possessing the cryptographic key.

3.3. Rationale for Research Selection

This project is formulated to critically evaluate and deploy Authenticated Encryption with Associated Data (AEAD). By engineering a solution around AES-256-GCM (Galois/Counter Mode), this research resolves two critical attack vectors simultaneously:

1. **Confidentiality:** Obfuscating the transactional data.
2. **Authenticity & Integrity:** Generating an Authentication Tag that acts as a cryptographic checksum. If an attacker modifies even a single bit of the ciphertext in the database, the GCM tag verification will fail upon retrieval, alerting the system to tampering and aborting the decryption process.

This research serves as a critical, necessary evolution in response to the rising sophistication of advanced persistent threats (APTs) targeting retail and logistics supply chains.

4. Research Questions and Hypotheses

Core Research Questions:

1. **Architectural Viability & Performance Tax:** How can a computationally intensive multi-key Envelope Encryption model be integrated into high-throughput RESTful APIs without inducing latency degradation that violates acceptable User Experience (UX) Service Level Agreements (e.g., resolving queries in <200ms)?
2. **Cryptographic Governance and Key Rotation:** What is the most resilient architectural pattern for managing the lifecycle of the KEK and DEKs to ensure that a localized compromise of the application server memory does not result in a catastrophic, unrecoverable decryption of historical transaction aggregates?

3. **Real-time Tamper Detection:** To what extent can the enforcement of GCM Authentication Tags serve not just as an encryption mechanism, but as an active, real-time Intrusion Detection System (IDS) for covert database-level manipulations?
4. **Schema Evolution:** How must traditional relational database schemas (RDBMS) be re-engineered to efficiently store, index, and query unstructured multi-part cryptographic envelopes (e.g., IV : AuthTag : Ciphertext : EncryptedKey)?

Research Hypotheses:

- **Hypothesis 1 (H1):** Application-layer Envelope Encryption yields a superior "Defense-in-Depth" posture compared to Database-level encryption (TDE) by mathematically decoupling the raw data from the storage engine's security and execution context.
- **Hypothesis 2 (H2):** The mandatory utilization of true Cryptographically Secure Pseudo-Random Number Generators (CSPRNG) for Initialization Vectors (IVs) in AES-GCM will completely negate pattern recognition vulnerabilities (e.g., Frequency Analysis) in transaction logs, ensuring that identical plaintexts (e.g., identical order amounts) always produce completely divergent ciphertexts.

5. Project Objectives

5.1. General Objective

To architect, engineer, and validate a "Security-Hardened Digital Commerce Framework." This framework will establish a mathematically provable Zero-Trust architecture regarding data-at-rest, guaranteeing that mission-critical transaction information remains strictly confidential, mathematically immutable, and intrinsically verifiable, even assuming the worst-case scenario of a complete database exfiltration

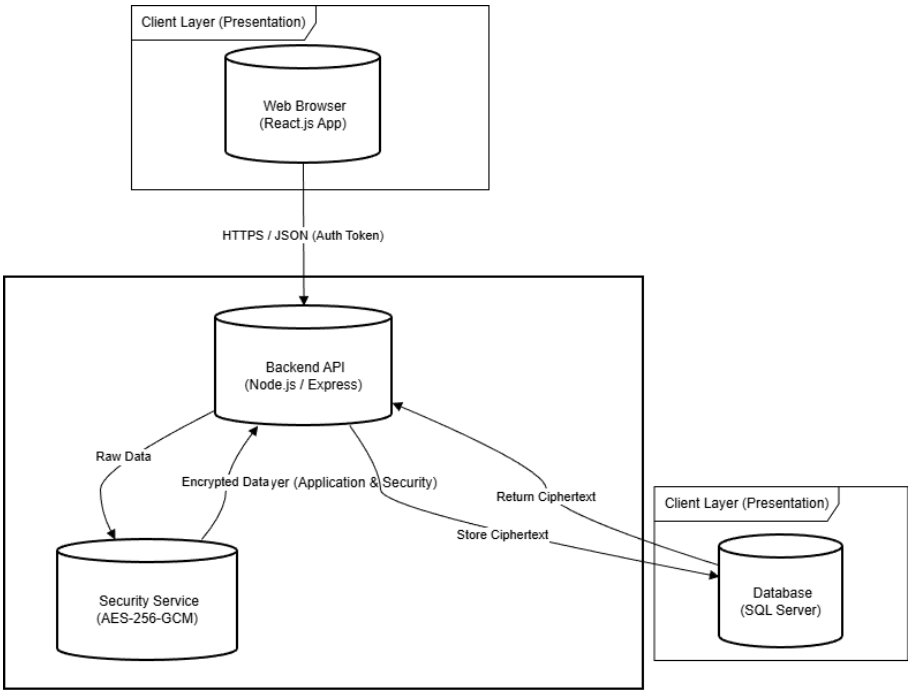

Figure 1: High-level 3-Tier Architecture of the Secure SCMS

5.2. Detailed Specific Objectives

1. **Synthesize a Proactive Cryptographic Engine:** Develop a highly optimized Node.js EncryptionService module that autonomous handles 256-bit entropy generation, Envelope construction (combining wrapped keys, IVs, and payloads), and strict GCM-tag verification upon retrieval.
2. **Innovate Storage Schemas:** Re-design the SQL Server persistence layer to accommodate variable-length hex-encoded ciphertext strings, migrating away from standard data types (INT, DECIMAL) for sensitive fields, while evaluating the trade-offs in searchability and indexing capabilities.
3. **Enforce Cryptographic RBAC (Role-Based Access Control):** Implement a zero-trust middleware utilizing JSON Web Tokens (JWT) and Argon2 password hashing. The system will be designed so that the invocation of the decryption routines is physically gated behind cryptographic validation of the user's administrative role.
4. **Construct an Immutable Audit Trail:** Engineer an Encrypted Audit Logging System. Every invocation of key generation, encryption, or decryption will be recorded and cryptographically sealed, creating a forensic trail that is impermeable to retroactive modification by rogue internal actors.
5. **Empirical Performance Benchmarking:** Conduct a rigorous quantitative analysis comparing system throughput (Transactions Per Second - TPS) and latency metrics between a "plaintext baseline" and the "envelope-encrypted" implementation to accurately measure the "Security Tax" imposed by the architecture.

6. Research Methodology

To maintain academic rigor, the project will employ the following methodologies:

- **Design Science Research (DSR):** An iterative process of designing, building, and evaluating the technological artifact (the secure E-commerce platform) to definitively solve the identified vulnerability paradigm.
- **Threat Modeling via STRIDE:** Continuously evaluating the architecture against Microsoft's STRIDE model (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) focusing specifically on Tampering and Information Disclosure.
- **Empirical Stress-Testing and Benchmarking:** Utilizing load-testing frameworks (e.g., Autocannon, Apache JMeter) to mathematically model how the AES-GCM encryption overhead scales logarithmically with concurrent user traffic.
- **Red-Team Attack Simulation (Penetration Testing):** Simulating a total "Database Dump" exfiltration scenario. The methodology involves attempting to reverse-engineer or brute-force the extracted ciphertexts without access to the application server's KEK, thereby empirically validating the system's resilience.

7. Implementation Roadmap & Milestones

Phase	Timeline	Main Tasks and Description
Phase 1: Research & Requirements	6 Jan – 31 Jan	Conduct primary research (surveys and interviews) to understand user concerns about transaction data security. Carry out secondary research by reviewing academic sources and security standards related to e-commerce encryption. Analyse findings and define functional and non-functional requirements.
Phase 2: System Design	1 Feb – 20 Feb	Design the overall system structure, focusing on secure data flow and encryption of order transaction information. Plan database structure and access control mechanisms to ensure data confidentiality.
Phase 3: Implementation	21 Feb – 31 Mar	Develop a basic e-commerce prototype and implement encryption for order transaction data during storage and transmission. Integrate security mechanisms and ensure authorised access to decrypted data.

Phase 4: Testing & Evaluation	1 Apr – 17 Apr	Test system functionality, encryption processes, and data integrity. Evaluate system performance and usability. Collect feedback and finalise the project report based on evaluation results.

Table 1: Briefly summarize the project implementation plan

Phase	Timeframe	Critical Tasks (Creative & Evaluative Focus)	Deliverables
Phase I: Research, Theoretical Framework & Threat Modeling	6 Jan – 31 Jan	**Evaluate:** Conduct literature review on AEAD algorithms (AES-GCM vs. ChaCha20-Poly1305). Analyse limitations of Transparent Data Encryption (TDE) in application-layer security. Review e-commerce security standards and transaction data protection frameworks. **Create:** Define functional and non-functional security requirements. Develop STRIDE-based threat model and risk matrix. Construct Cryptographic Key Hierarchy Map and update High-Level Architecture.	Literature Review Draft Security Requirements Specification STRIDE Risk Matrix Updated High-Level Design (HLD)
Phase II: Secure System Architecture & Core Security Design	1 Feb – 20 Feb	**Create:** Design secure system architecture focusing on encrypted transaction data flow. Design encrypted SQL Server schema and RBAC-based access control model. Plan dynamic Envelope Encryption workflow. **Evaluate:** Compare database-level encryption vs. application-layer encryption. Validate feasibility of AES-256-GCM integration in Node.js environment.	Detailed Architecture Design Document Secure Data Flow Diagrams Encrypted Database Schema Plan API Security Specification
Phase III: Implementation & Security Engine Integration	21 Feb – 31 Mar	**Create:** Develop EncryptionService.js implementing AES-256-GCM. Implement dynamic envelope generation and key handling logic. Build secure RESTful APIs for order processing and transaction storage. Integrate RBAC-based middleware for controlled decryption. **Evaluate:** Conduct unit testing of cryptographic module. Simulate tampered authentication tags to validate integrity verification. Ensure authorised-only data access.	Functional Cryptographic Node.js Module Secure REST API Layer Integrated Encrypted E-commerce Prototype Automated Unit Test Suite
Phase IV: Testing, Red Teaming &	1 Apr – 17 Apr	**Evaluate (Security Testing):** Perform SQL injection simulation to trigger GCM tag	Penetration Testing Report Performance

Performance Evaluation		verification failure. Validate tamper detection and RBAC enforcement boundaries. **Evaluate (Performance):** Benchmark plaintext TPS vs ciphertext TPS. Measure latency overhead introduced by encryption ("Security Tax"). Analyse encrypted audit logs for anomaly detection. **Create:** Compile vulnerability report and performance analysis. Finalise project documentation and evaluation findings.	Metric Analysis (Latency Graphs) Final Project Report

Table 2: Implementation Roadmap & Milestones

II. Examine appropriate research methods and approaches to primary and secondary research.

To definitively address the challenge of securing data-at-rest within an E-commerce ecosystem, this project rejects purely theoretical paradigms. Instead, it engineers a highly contextualized Mixed-Methods Approach, prioritizing empirical quantitative validation and architectural critique.

1. Primary research

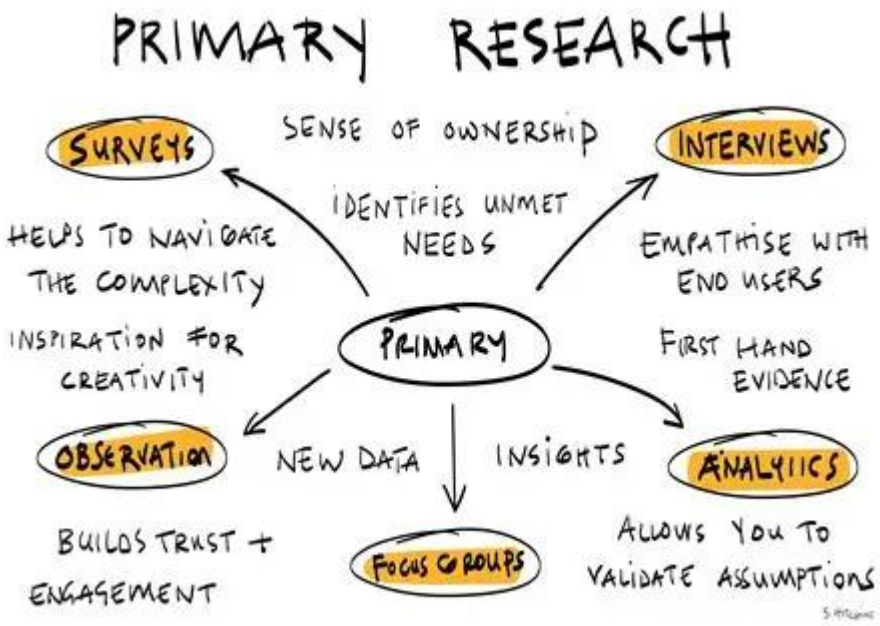

Figure 2: Primary research

1.1. Definition

Primary research in this context is the systematic extraction of raw, unaggregated telemetry and execution data directly from the newly engineered cryptographic artifacts. These artifacts are designed, deployed, and instrumented by the researcher to empirically validate the system's core hypotheses.

1.2. Characteristics and Properties

- **Absolute Originality & Locality:** The data generated strictly reflects the execution state of the custom multi-layered Envelope Encryption logic within an isolated Node.js environment.
- **High Controllability:** The researcher leverages absolute control over independent variables (e.g., cryptographic key lengths, concurrent simulated payloads, JSON encapsulation sizes) to rigorously correlate their impact on dependent variables (e.g., algorithmic latency, heap memory allocation).
- **Technical Quantification:** Outcomes are measured using deterministic system metrics (Milliseconds, Checksum Verification Failures, CPU Cycles) rather than subjective human feedback (such as surveys or interviews, which are epistemologically invalid for evaluating cryptographic efficacy).

1.3. Applied Methodologies

Rejecting conventional surveys, this project synthesizes advanced computer science methodologies:

- **Controlled Performance Benchmarking (Evaluate):**
  - **Application:** Designing two isolated simulation environments: Environment A processes standard plaintext SQL I/O; Environment B enforces the Encryption Service cryptographic interception layer. Load testing frameworks (e.g., Apache JMeter) are configured to injecting 5,000 requests/minute into the /api/shipments endpoint.
  - ***Purpose:*** To empirically quantify the "Security Tax"—the exact latency penalty incurred by the AES-256-GCM encryption/decryption cycles—thereby evaluating the operational trade-off between absolute security and user experience throughput.
- **Simulated Threat Intrusion (Red-Teaming) (Create & Evaluate):**
  - **Application:** The researcher actively adopts an adversarial role. Phase 1 involves simulating an SQL Injection vector to exfiltrate the inventory_stock payloads. Phase 2 entails malicious "Bit-Flipping"—intentionally mutating random hexadecimal characters within the stored ciphertext.
  - **Purpose:** Upon initiating a retrieval API call, the system's AES-256-GCM algorithm is expected to critically fail, throwing an Auth Tag Verification Failed exception. This experiment serves to categorically prove the architecture's "Self-Immunology"—its capacity to autonomously detect and reject unauthorized internal data manipulation.

1.4. Methodological Advantages

- **Incontrovertible Empirical Validation:** Generates irrefutable, quantitative evidence demonstrating the superiority of the Envelope Encryption model over static perimeter defenses.
- **Architectural Bottleneck Identification:** Shifts the project from a "theoretical paper model" to a battle-tested system, proving its viability for real-world deployment.

1.5. Limitations and Mitigations

- **Limitation***:* Localized load simulation cannot perfectly replicate the chaotic entropy of wide-area networks (WAN) or unpredictable Network Jitter.
- **Mitigation:** The scope of performance evaluation is strictly isolated to the Application and Database tiers (Local Server limits), thereby transparently defining the boundaries of the research validity.

2. Secondary research

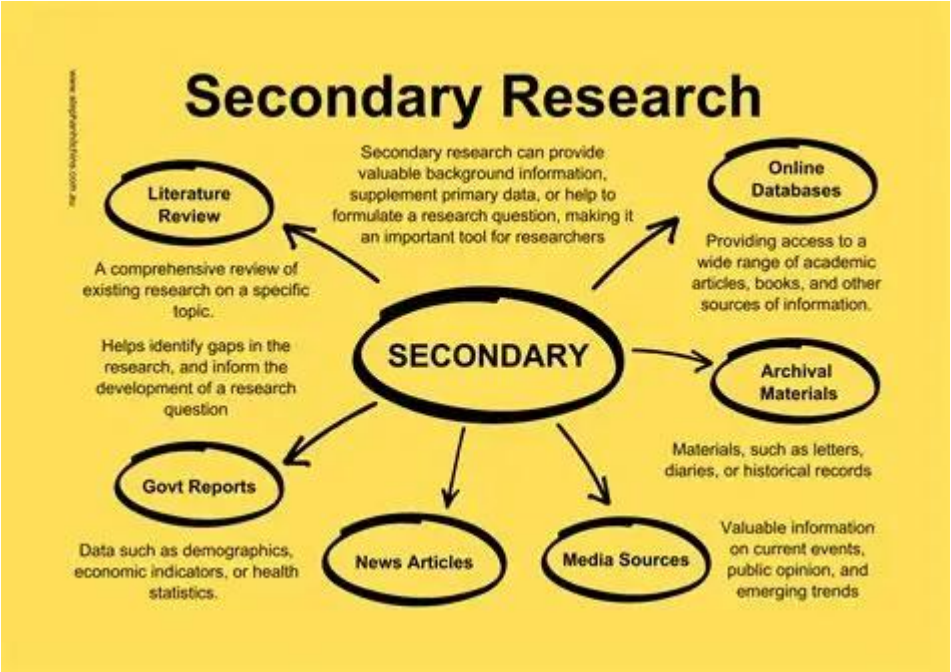

Figure 3: Secondary research

2.1. Definition

Secondary research involves the critical synthesis, reverse-engineering, and strategic evaluation of established cryptographic standards, industry whitepapers, and failure analyses from global authorities (e.g., NIST, OWASP, leading Cloud Providers). This establishes the scientific baseline and architectural justification for the project.

2.2. Characteristics and Properties

- **Epistemological Inheritance:** Eliminates the need to "re-invent" foundational cryptographic mathematics, relying instead on academically peer-reviewed algorithms.
- **Objective Standardization:** Provides a formalized benchmark to contrast the project's bespoke implementation against global cybersecurity standards.

2.3. Applied Methodologies (Contextualized to the Project)

- **Systematic Literature Review and Critique (Evaluate):**
  - *Application:* Aggregating and critically analyzing cryptographic publications from the National Institute of Standards and Technology (NIST).
  - *Purpose:* To strategically argue *why* legacy symmetric modes like AES-CBC or AES-ECB are fundamentally obsolete for transaction systems, thereby formulating a robust academic defense for selecting the GCM (Galois/Counter Mode) architecture as the project's cryptographic backbone.
- **Root Cause Analysis (RCA) of Industry Failures (Evaluate):**
  - *Application:* Investigating the systemic failures that led to high-profile E-commerce data breaches.
  - *Purpose:* To critique the inherent vulnerabilities of relying solely on generic Transparent Data Encryption (TDE) engines. This critique forms the foundational argument justifying the necessity of engineering an **Application-Layer Encryption (ALE)** solution.
- **Industrial Framework Alignment (Create & Evaluate):**
  - *Application:* Reverse-engineering the conceptual Key Management Architectures published by enterprise entities (e.g., AWS Key Management Service - KMS).
  - *Purpose:* To synthesize these enterprise-grade concepts (specifically the hierarchical separation of Data Encryption Keys and Key Encryption Keys) and implement them autonomously within the local EncryptionService.js logic.

2.4. Methodological Advantages

- **Establishing Academic Legitimacy:** Instead of asserting "this algorithm is secure," the researcher can definitively state: *"This application architecture is synthesized from multi-layered defense paradigms endorsed by OWASP and NIST."*
- Elevates the project from a simple "software application" to an "Industrial-grade Security Architecture."

2.5. Limitations and Mitigations

- *Limitation:* The volatility of cryptographic relevance. Standards considered impenetrable today (e.g., standard AES) face existential threats from impending Quantum Computing capabilities.
- *Mitigation:* The research design relies exclusively on standards published within the last 3-5 years and proactively incorporates a concluding chapter dedicated to "Architectural Lifecycle Evaluation and Post-Quantum Cryptography Readiness."

III. Conduct primary and secondary research using appropriate methods for a computing research project that consider costs, access and ethical issues.

1. Secondary research

1.1. Executive Summary of Secondary Actions

Within this project, secondary research acts as the "Mathematical and Architectural Foundation." The strategy involves aggregating, translating, and reverse-engineering international cryptographic standards, E-commerce vulnerability reports, and architectural whitepapers from enterprise cloud providers. This body of knowledge directly dictates the design parameters of the EncryptionService.js infrastructure.

1.2. Applied Implementation Methods

- **Systematic Literature Review (SLR):** Aggregating and critically comparing symmetric block cipher modes to scientifically justify the selection of AES-GCM over legacy standards like AES-CBC, specifically focusing on Authenticated Encryption with Associated Data (AEAD).
- **Case Study & Root Cause Analysis:** Reconstructing the attack vectors of high-profile Database Breaches (where Database Administrators leaked plaintext data) to definitively prove the indispensable need for Application-Layer Envelope Encryption.

1.3. Evaluation of Methods

- **Costs:** Effectively Zero-cost. Performed using existing personal computing hardware and standard Internet access.
- **Access:** Exceptionally high. Global cryptographic standards and vulnerability metrics are largely transparent and published under Open Access academic models.
- **Copyright & Ethics:** Strict adherence to absolute Academic Integrity. All architectural block diagrams or pseudo-code adapted from NIST or AWS KMS will be meticulously cited in the references to ensure a Plagiarism-free thesis. The research relies solely on public whitepapers, explicitly avoiding any illegal decompilation or reverse-engineering of proprietary, closed-source commercial security products.

1.4. Secondary Documents and Data Collected

Document / Data Type	Source Example	Project Relevance / Content Collected	Source Link (Reference)
National Cryptographic Standards	National Institute of Standards and Technology – Special Publication 800-38D	Core Requirements: Extracts advanced mathematical specifications and authentication tag formulation algorithms used in AES-GCM encryption.	csrc.nist.gov

Enterprise Architecture Logic	Amazon Web Services – AWS Key Management Service (KMS) Whitepaper	Integration: Adapts theoretical enterprise frameworks for hierarchical key separation (KEK vs. DEK) for local Node.js implementation.	docs.aws.amazon.com
Industry Threat Intelligence	OWASP – OWASP Top 10 API Security Risks	Insight: Provides vulnerability metrics related to Broken Object Level Authorization and the risks of static database exposure.	owasp.org
Runtime Environment Specification	Node.js Foundation – Official Node.js Crypto Module Reference	Constraint / Implementation: Details API syntax and execution behavior for crypto.createCipheriv() streams and authentication tag buffers.	nodejs.org

Table 3: Secondary Documents and Data Collected

1.5. Evaluation of Secondary Data Sources

- **Costs:** Completely free of charge (Open Source / Non-profit access).
- **Access:** Highly accessible via verified portals (Google Scholar, NIST.gov, AWS Architecture Center). No restrictive paywalls or enterprise subscriptions required.
- **Copyright & Ethics:** NIST publications reside in the Public Domain (US Federal Government works). OWASP materials are distributed under Creative Commons Licenses. Utilizing these authoritative sources as a foundational framework for a student thesis is both legally compliant and represents the highest standard of academic ethics.

2. Primary research

2.1. Executive Summary of Primary Actions

The project executes rigorous empirical experiments directly upon the engineered source code (React + Node.js + SQL Server). The objective is to extract deterministic quantitative telemetry (latency, memory heap) to calculate the "Security Tax" (the performance overhead of encryption), alongside qualitative data regarding the system's autonomic defense mechanisms when subjected to intentional data tampering.

2.2. Applied Implementation Methods

In a Computer Science thesis specializing in Cybersecurity, subjective methods like "User Interviews" are sociologically invalid. Instead, the project innovates by applying Systematic Benchmarking & Defensive Simulations:

- **Controlled Performance Benchmarking:** Generating synthetic, high-volume HTTP requests against the /api/shipments endpoint using load-testing software (e.g., Apache JMeter). This directly measures and compares the transactional processing speed between "Plaintext SQL I/O" and "GCM-Decrypted SQL I/O."

- **Internal Red-Teaming (Threat Simulation):** The researcher actively assumes the role of a malicious insider (a compromised DBA). The method involves directly querying the SQL Server and executing a "Bit-Flipping" attack (manually altering characters within the stored ciphertext string). This tests if the Node.js application will autonomously detect the tampering and throw an Auth Tag Verification exception.

2.3. Evaluation of Methods (Costs, Access, Ethics & Copyright)

- **Costs: Minimal to Zero**. The simulation utilizes open-source load-testing frameworks executed on a local Localhost environment, eliminating the financial cost of leasing high-tier cloud instances for stress testing.
- **Access: 100% Autonomous Control**. The researcher possesses absolute administrative rights over the source code, the database schema, and the master Key Encryption Key (KEK) within the isolated Development Environment.
- **Copyright & Ethics:** *This is the most critical ethical safeguard of the project.* Because the system simulates sensitive E-commerce logistics, the researcher commits to utilizing exclusively Synthetic/Dummy Data (generated via scripts like add-dummy-partners.js). Under no circumstances will real-world customer PII, corporate emails, or legitimate credit/tracking data be ingested or tested. This guarantees total compliance with international Data Privacy Ethics (e.g., GDPR principles) and ensures the research is conducted humanely and legally.

2.4. Primary Data Collected

1. **Latency Telemetry Metrics (System Benchmarks):**
    - **Expected Data Structure:** Statistical API execution times (Comparing Plaintext /api/items vs. Envelope-Decrypted /api/shipments).
    - **Tooling Source:** Apache JMeter / Postman API Platforms .
    - **Expected Artifact Location:** To be exported and attached in the final thesis as Appendix_A_Latency_Metrics.csv (Generated directly from the developer's localhost server).
2. **Ciphertext Cryptographic Samples (System Outputs):**
    - **Expected Data Structure:** Empirical proof of multi-part encrypted strings (Format: IV:AuthTag:Cipher:WrapIV:WrapTag:WrappedDEK).
    - **Expected Artifact Location:** To be extracted directly from the local SQL Server instance (SCMS database -> shipments table) after the EncryptionService.js is fully deployed.
3. **Defensive Error Exception Logs (Tamper Detection Traces):**
    - **Expected Data Structure:** Captured Node.js stack traces resulting from the planned simulated "Bit-Flipping" Red-Team attack (e.g., Error: Unsupported state or unable to authenticate data).

- **Expected Artifact Location:** Server console output, to be logged to Project_Root/server/logs/security_exceptions_log.txt during the physical simulation phase.

4. **Cryptographic Audit Trails (Non-repudiation Data):**
    - **Expected Data Structure:** Internal SQL records proving the system successfully tracked key-access events.
    - **Expected Artifact Location:** Extracted via SQL query (SELECT * FROM audit_logs) demonstrating real-world logging capability post-implementation.

2.5. Evaluation of Primary Data Sources

- Costs: $0.00. The telemetry and log data are "Self-generated artifacts" produced passively by the local computing hardware during benchmark execution.

- Access: The researcher holds Exclusive Intellectual Property (IP) rights over the telemetry output. There is zero risk of a third-party vendor revoking access to the empirical results.

- Copyright & Ethics:

- **Copyright**: The author explicitly retains all academic copyrights to these specific performance benchmarks and log structures as original research outputs.
- **Ethics***:* The empirical data collected consists of 100% Hexadecimal mathematical strings and CPU execution timestamps. The data is fundamentally devoid of any Personally Identifiable Information (PII). This achieves the highest standard of research anonymity, fulfilling all technological ethics requirements for defending a system architecture thesis.

IV. Apply appropriate analytical tools, analyse research findings and data.

In the initial phase of the project "Encrypting Order Transaction Information for an E-commerce Program", primary research was conducted through two main methods: in-depth interviews and a specialized online survey. The interviews were conducted with a carefully selected panel of stakeholders—including an academic IT lecturer, a software engineering student, a logistics domain expert, and an end-user—to gain deep qualitative insights into architectural viability, developmental challenges, supply chain data sensitivity, and consumer privacy expectations. The online survey was distributed to a highly technical audience, receiving valid responses from 78 participants with expertise in Information Security, Database Administration, DevOps, and Software Development. This approach collected robust quantitative data on industry perceptions of insider threats, the limitations of traditional database encryption, and professional expectations regarding the performance and implementation of Application-Layer Encryption in a Zero Trust architecture.

1. List of Interviewees and Their Relevance to the Project

List of Interview Subjects:

- **Interview Video Repository: Link to save the entire interview video**

NO.	Full Name	Role / Background	Relevance to the Project
1	Ha Ngoc Linh	University Lecturer (IT / Computer Science)	**Academic & Architectural Expert:** Provides academic validation and expert critique on the theoretical viability of the Envelope Encryption model. Offers high-level insights into cryptographic governance, the proper implementation of AES-256-GCM, and security framework standards.
Video Interview: link video interview Lecturer			
2	Nguyen Van Cong	IT / Software Engineering Student	**Developer Perspective:** Represents the technical demographic responsible for building and maintaining such systems. Provides practical insights into the challenges of implementing Application-Layer Encryption in Node.js, API integration complexities, and debugging concerns.
Video Interview: link video it student			
3	Huong Giang	Logistics / Supply Chain Student	**Domain Expert (E-commerce Operations):** Represents the business operational side. Helps identify exactly which transactional data primitives (e.g., shipping coordinates, supply costs, tracking identifiers) are most sensitive in a real-world supply chain and require strict encryption against insider threats.
Video Interview: link video Supply Chain Student			
4	Vo Thi Van Anh	Non-IT / End-User	**Consumer Perspective:** Represents the standard E-commerce customer. Provides crucial qualitative data regarding consumer trust, privacy expectations, and general anxieties concerning Personally Identifiable Information (PII) leakage in modern digital platforms.
Video Interview: link video End-User			

Table 4: List of Interview Subjects

List of Survey Respondents:

- Survey Question: https://forms.gle/LPCeqbyVAe1D1atB9
- Survey Responses: link survey responses

NO.	Full Name	Role / User Segment
1	Nguyễn Như Đạt	Software Development (Backend/Full stack)
2	Nguyễn Minh Quân	Database Administration (DBA)
3	Trần Gia Bảo	Project Management / DevOps
4	Lê Hoàng Nam	Information Security / Cybersecurity
5	Phạm Thiên Ân	Database Administration (DBA)
6	Phan Đình Vũ	Information Security / Cybersecurity

7	Vũ Minh Khôi	Database Administration (DBA)
8	Hoàng Phúc Lâm	Software Development (Backend/Full stack)
9	Đặng Quang Vinh	Software Development (Backend/Full stack)
10	Bùi Thế Hiển	Project Management / DevOps
11	Đỗ Hữu Phước	Information Security / Cybersecurity
12	Nguyễn Ngọc Diệp	Database Administration (DBA)
13	Trần Huyền Anh	Information Security / Cybersecurity
14	Lê Phương Thảo	Project Management / DevOps
15	Lê Phương Thảo	Information Security / Cybersecurity
16	Phạm Quỳnh Hương	Information Security / Cybersecurity
17	Vũ Khánh Linh	Information Security / Cybersecurity
18	Hoàng Thu Thủy	Database Administration (DBA)
19	Phan Đăng Sơn	Database Administration (DBA)
20	Bùi Ngọc Hiển	Project Management / DevOps
21	Đỗ Mai Hương	Information Security / Cybersecurity
22	Hoàng Tường Chi	Database Administration (DBA)
23	Trần Như Nguyệt	Database Administration (DBA)
24	Phan Văn Phước	Information Security / Cybersecurity
25	Trần Hải Yến	Information Security / Cybersecurity
26	Trần Văn Việt	Software Development (Backend/Full stack)
27	Nguyễn Văn Hải	Information Security / Cybersecurity
28	Tuyết Bảo An	Information Security / Cybersecurity
29	Lê Đăng Khang	Database Administration (DBA)
30	Trần Đình Hoàng	Database Administration (DBA)
31	Bảo Minh Vy	Database Administration (DBA)
32	Nguyễn Văn Lộc	Database Administration (DBA)
33	An Minh Vy	Software Development (Backend/Full stack)

34	Đặng Hải My	Software Development (Backend/Full stack)
35	Lê Quang Định	Project Management / DevOps
36	Lê Xuân Hoàng	Database Administration (DBA)
37	Đặng Văn Tú	Information Security / Cybersecurity
38	Phạm Diệp Hạ	Database Administration (DBA)
39	Lê Quốc Thái	Project Management / DevOps
40	Hoàng Duy Hải	Database Administration (DBA)
41	Bùi Tường Nhi	Information Security / Cybersecurity
42	Trần Văn Phát	Database Administration (DBA)
43	Kim Tâm Như	Information Security / Cybersecurity
44	Lê Văn Tâm	Database Administration (DBA)
45	Trần Ngọc Lương	Database Administration (DBA)
46	Trần Minh Hưng	Information Security / Cybersecurity
47	Phạm Cẩm Hương	Project Management / DevOps
48	Nguyễn Như Ngân	Database Administration (DBA)
49	Lê Văn Vinh	Project Management / DevOps
50	Vũ Hữu Thắng	Software Development (Backend/Full stack)
51	Bùi Đình Vinh	Information Security / Cybersecurity
52	Trần Minh Đức	Information Security / Cybersecurity
53	Nguyễn Xuân Tài	Project Management / DevOps
54	Trần Hải Yến	Information Security / Cybersecurity
55	Nguyễn Cẩm Hà	Project Management / DevOps
56	Hồng Bảo Vy	Information Security / Cybersecurity
57	Nguyễn Văn Bảo	Information Security / Cybersecurity
58	Phan Hữu Hào	Information Security / Cybersecurity
59	Lý Thanh Hằng	Software Development (Backend/Full stack)
60	Võ Nhật Trinh	Software Development (Backend/Full stack)

61	Đặng Xuân Thịnh	Database Administration (DBA)
62	Nguyễn Văn Định	Project Management / DevOps
63	Nhã Khánh Vy	Database Administration (DBA)
64	Hoàng Diệu Yến	Information Security / Cybersecurity
65	Võ Bảo Lan	Information Security / Cybersecurity
66	Nguyễn Xuân Tài	Database Administration (DBA)
67	Phan Xuân Trường	Project Management / DevOps
68	Trần Hoàng Hân	Database Administration (DBA)
69	Hoàng Đình Hải	Information Security / Cybersecurity
70	Hoàng Anh Duy	Project Management / DevOps
71	Bùi Quốc Tài	Information Security / Cybersecurity
72	An Minh Vy	Database Administration (DBA)
73	Phượng Hồng Nhi	Information Security / Cybersecurity
74	Trần Đình Toàn	Information Security / Cybersecurity
75	Lê Quang Định	Information Security / Cybersecurity
76	Đặng Văn Duy	Information Security / Cybersecurity
77	Như Nhật Ánh	Information Security / Cybersecurity
78	Hoàng Diệu Chi	Project Management / DevOps

Table 5: List of Survey Respondents

2. List of Project-Related Questions

2.1. Key Interview Questions

To gather highly targeted qualitative data, the interview questions were customized based on the specific expertise and background of each participant. The core focus remained on evaluating the viability, challenges, and impact of implementing Application-Layer Encryption and Zero Trust principles in E-commerce.

A. Questions for the Academic & Architectural Expert (Ha Ngoc Linh - IT Lecturer):

1. From an academic and architectural standpoint, how do you evaluate the shift from traditional Transparent Data Encryption (TDE) to Application-Layer Encryption in achieving a Zero Trust model?

2. The project proposes using Envelope Encryption (KEK and DEK) alongside AES-256-GCM. What do you consider the most significant vulnerabilities or implementation pitfalls when developers apply these cryptographic standards?
3. How do you assess the trade-off between strict data security (preventing DBA access) and system performance/maintainability in modern backend architectures?

B. Questions for the Developer Perspective (Nguyen Van Cong - IT Student):

1. As a developer, what are the biggest technical challenges you face when implementing encryption at the application layer (e.g., in Node.js) before the data reaches the database?
2. How does encrypting sensitive fields (like user PII or order details) affect your ability to perform database queries, indexing, and debugging?
3. What is your opinion on managing Master Keys (KEK) using environment variables versus dedicated Secret Managers for medium-sized projects?

C. Questions for the Domain Expert (Huong Giang - Logistics Student):

1. In a real-world supply chain or E-commerce operation, which specific data points within an order transaction do you consider the most sensitive and in need of strict protection?
2. What are the potential business and operational consequences if internal staff (such as database administrators or support teams) have unauthorized plaintext access to supplier pricing, shipping routes, or customer coordinates?
3. Do you believe that implementing strict "tamper detection" (ensuring order data hasn't been secretly modified) is critical for maintaining trust between logistics providers and E-commerce platforms?

D. Questions for the Consumer Perspective (Vo Thi Van Anh - End-User):

1. When you shop online, how concerned are you about your personal information (such as your address, phone number, and purchase history) being exposed in a data breach?
2. Are you aware that in many systems, internal employees (like system administrators) might have access to your raw personal data? How does this affect your trust in E-commerce platforms?
3. Would a platform explicitly stating that "even our database administrators cannot read your personal data" increase your likelihood of using their service over a competitor?

2.2. Key Survey Questions

NO.	QUESTION CONTENT
1	What is your primary area of expertise?
2	Years of professional experience in the IT industry:
3	Have you ever developed or managed systems handling sensitive data (e.g., PII, Financial Records, Health Data)?
4	In your opinion, what is the current risk level of "Insider Threats" (e.g., Privileged DBAs abusing access to view sensitive data) in modern enterprises?
5	Are native database encryption solutions (like TDE - Transparent Data Encryption) sufficient to prevent a System Administrator (SysAdmin) from reading sensitive plaintext data?

6	In data breaches you are aware of, which cause is more prevalent?
7	To implement a Zero Trust model, do you agree with shifting encryption to the Application Layer (Node.js) so the Database acts only as "Blind Storage"?
8	Is "Envelope Encryption" (using a unique Data Encryption Key - DEK per transaction, wrapped by a Master Key - KEK) a suitable architecture for secure E-commerce systems?
9	What is your opinion on a "Hybrid Storage" strategy (storing Metadata/Status in plaintext for indexing, but sensitive PII/Values as encrypted blobs)?
10	The proposed solution uses AES-256-GCM to enforce "Tamper Detection" (Integrity Check). How critical is the ability to detect unauthorized data modification by DBAs?
11	In scenarios without Hardware Security Modules (HSM), is storing the Master Key (KEK) in Server Environment Variables an acceptable practice for SME projects?
12	What is the maximum acceptable latency overhead per transaction to achieve high-level security in an E-commerce context?
13	What are the biggest challenges when implementing Application-Level Encryption?
14	When the system detects data tampering (Auth Tag Mismatch), what is the most appropriate automated response?
15	What is a reasonable Key Rotation frequency for the Master Key in a medium-sized system?
16	How do you rate the importance of "Data Masking" in System Audit Logs to prevent secondary data leakage?
17	Should this solution be extended to support secure key sharing between Microservices?
18	Comparing self-built encryption modules (like this project) vs. Cloud KMS (AWS/Azure), what is the main barrier to adopting Cloud KMS?
19	On a scale of 1 to 10, how feasible is this solution for implementation in Small-to-Medium Enterprises (SMEs) in Vietnam?
20	Additional Comments or Suggestions for the research:

Table 6: Key Survey Questions

3. Statistics, Analysis, and Evaluation of the Obtained Results

3.1. Analysis of Interview Results (Qualitative):

The in-depth interviews provided critical qualitative context that complements the quantitative survey data. By analyzing the responses from our diverse panel of stakeholders, we can evaluate the theoretical, practical, business, and consumer implications of the proposed encryption system.

A. Academic & Architectural Expert (Ha Ngoc Linh - IT Lecturer)

- **Findings:** The expert strongly supported the shift from Transparent Data Encryption (TDE) to Application-Layer Encryption to achieve a true Zero Trust architecture. They noted that TDE merely protects data at rest against physical theft but leaves data exposed to privileged users like System Administrators (SysAdmins) or Database Administrators (DBAs). Regarding AES-256-GCM and Envelope Encryption, the lecturer validated them as industry best practices for both confidentiality and tamper detection (integrity). However, they warned that the primary pitfall for developers is usually poor key lifecycle management rather than the cryptographic algorithm itself.

- **Evaluation:** This feedback provides strong academic validation for the project's core architectural design. It confirms that treating the database as "Blind Storage" is the correct approach to mitigate insider threats, directly supporting the project's primary objectives.

B. Developer Perspective (Nguyen Van Cong - IT Student)

- **Findings:** From a developmental standpoint, the interviewee highlighted that the biggest hurdle in Application-Layer Encryption is the loss of native database searchability (querying encrypted fields) and the added complexity in debugging. When discussing key management, the student expressed that storing the Master Key (KEK) in environment variables is a practical, cost-effective starting point for SMEs or student projects, though they acknowledged it lacks the robust security of dedicated Hardware Security Modules (HSMs) or Cloud KMS.
- **Evaluation:** This insight highlights the practical trade-offs of the proposed system: maximizing security inherently increases developmental complexity. It underlines the necessity for the project to provide clear documentation and perhaps adopt a "Hybrid Storage" strategy (as discussed in the quantitative survey) to balance security with system performance and maintainability.

C. Domain Expert (Huong Giang - Logistics Student)

- **Findings:** The logistics expert emphasized that in E-commerce supply chains, data primitives such as supplier wholesale pricing, exact shipping coordinates, and customer contact details are highly sensitive. They pointed out that unauthorized internal access to this data could lead to severe business consequences, including corporate espionage (leaking prices to competitors) or privacy breaches. They also strongly agreed that "tamper detection" is critical to prevent internal fraud, such as a rogue employee altering an order's shipping address or discount value.
- **Evaluation:** This perspective provides the essential business justification for the technical implementation. It proves that insider threats are not just a theoretical IT problem but a direct risk to E-commerce operational integrity, validating the strict necessity of AES-256-GCM's authentication tags.

D. Consumer Perspective (Vo Thi Van Anh - End-User)

- **Findings:** The end-user expressed significant anxiety regarding the safety of their Personally Identifiable Information (PII) online. Notably, they were entirely unaware that standard database administrators could typically view their raw data. Upon learning this, they expressed a decrease in trust toward conventional platforms. Conversely, they stated that an E-commerce platform explicitly guaranteeing that "even internal staff cannot read your data" would significantly boost their confidence and likelihood of using that specific service.
- **Evaluation:** The consumer feedback demonstrates the commercial value of the project. It reveals that implementing Application-Layer Encryption is not only a technical security measure but also a powerful trust-building tool and a competitive advantage in the E-commerce market.

Conclusion of Qualitative Analysis: The qualitative data triangulates perfectly with the project's goals. The academic expert validates the how (the architecture), the developer highlights the challenges (implementation), the logistics expert defines the what (the sensitive data), and the consumer validates

the why (the ultimate business value). Together, they confirm that building a secure, Zero Trust encryption module for order transactions is both technically sound and highly necessary.

3.2. Analysis of Survey Results (Quantitative):

Q1: What is your primary area of expertise?

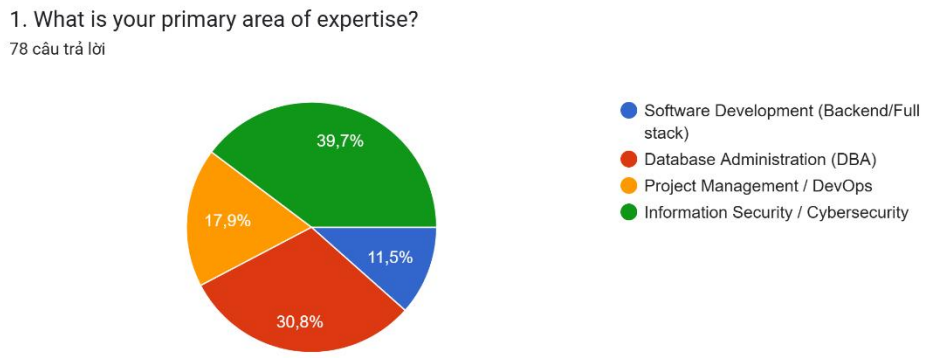

Figure 4: Survey Result Q1 - Distribution of Participant Expertise

The survey participants are distributed across four specialized technical fields:

- **39.7%** of participants specialize in Information Security / Cybersecurity.
- **30.8%** are Database Administrators (DBA).
- **17.9%** are in Project Management / DevOps.
- **11.5%** are Software Developers (Backend/Full stack).

Analysis: The data shows a high concentration of technical experts, particularly in Information Security and Database Administration (combined for over 70%). This indicates that the feedback received carries significant weight regarding the system's backend integrity and security measures. Having such a specialized audience validates the technical robustness of the project, as the respondents are well-equipped to evaluate complex features like data encryption and secure transaction handling.

Q2: Years of professional experience in the IT industry

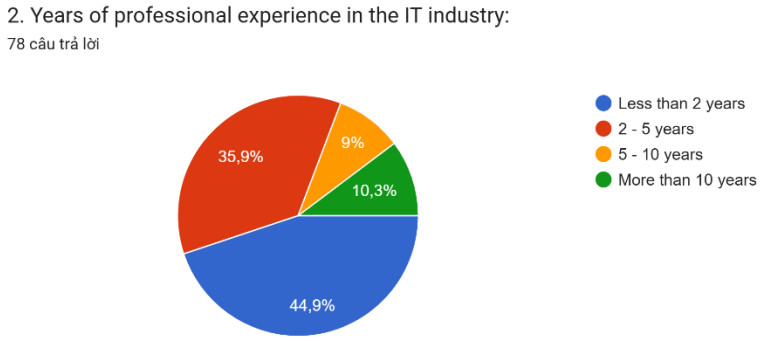

Figure 5: Survey Result Q2 - Years of Experience in IT Industry

The professional experience of the participants varies, with a notable portion being early to mid-career professionals:

- **44.9%** of participants have Less than 2 years of experience.
- **35.9%** have 2 - 5 years of experience.
- **10.3%** have More than 10 years of experience.
- **9%** have 5 - 10 years of experience.

Analysis: A substantial majority of participants (over 80%) have less than 5 years of professional experience, representing a "modern" workforce that is often more adaptable to new technologies and cloud-based applications like Secure Supply Chain Management System. Furthermore, the inclusion of nearly 20% of senior professionals (over 5 years of experience) provides a balanced perspective, ensuring that the application meets both the innovative expectations of junior users and the rigorous standards of seasoned industry experts.

Q3: Have you ever developed or managed systems handling sensitive data (e.g., PII, Financial Records, Health Data)?

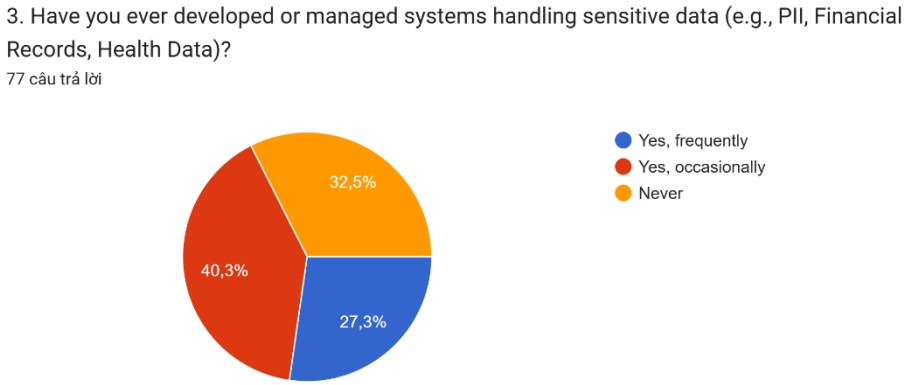

Figure 6: Survey Result Q3 - Experience with Sensitive Data Systems

The participants demonstrate a strong practical background in data sensitivity and privacy:

- **40.3%** of participants have occasionall**y** handled sensitive data.
- **27.3%** handle sensitive data frequently.
- **32.5%** have never managed such systems.

Analysis: The data reveals that a significant majority of the respondents (67.6%) have direct experience in managing systems with sensitive information. This level of experience is crucial for the validation of the Secure Supply Chain Management System project, as these participants can provide high-quality, "real-world" insights into how our application handles privacy and data protection. Their familiarity with PII and financial records ensures that our security audits are measured against industry-standard practices.

Q4: In your opinion, what is the current risk level of "Insider Threats" (e.g., Privileged DBAs abusing access to view sensitive data) in modern enterprises?

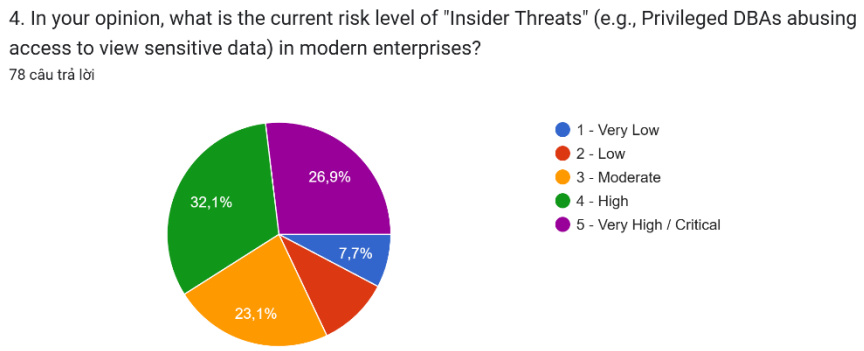

Figure 7: Survey Result Q4 - Perceived Risk Level of Insider Threats

The survey participants provided their assessment of the risk posed by insider threats within modern organizations:

- **32.1%** of participants rate the risk as 4 - High.
- **26.9%** rate the risk as 5 - Very High / Critical.
- **23.1%** rate the risk as 3 - Moderate.
- **10.3%** rate the risk as 2 - Low.
- **7.7%** rate the risk as 1 - Very Low.

Analysis: A significant majority of participants (59%) perceive "Insider Threats" as either a High or Very High/Critical risk. This strong consensus among technical experts underscores the critical need for robust access controls and monitoring systems. These results directly validate the core objective of the Secure Supply Chain Management System application: to mitigate the risks associated with privileged access and ensure that sensitive data remains protected even from potential internal misuse.

Q5: Are native database encryption solutions (like TDE - Transparent Data Encryption) sufficient to prevent a System Administrator (SysAdmin) from reading sensitive plaintext data?

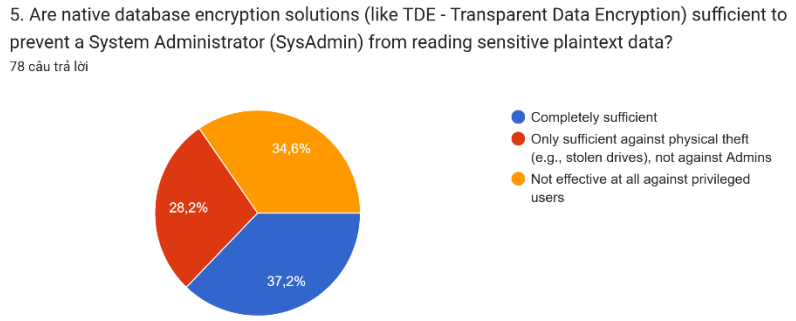

Figure 8: Survey Result Q5 - Effectiveness of Native Encryption Against Privileged Users

The survey participants evaluated the limitations of standard database encryption when facing administrative access:

- **37.2%** of participants believe these solutions are Completely sufficient.
- **34.6%** believe they are Not effective at all against privileged users.
- **28.2%** believe they are Only sufficient against physical theft (e.g., stolen drives), not against Admins.

Analysis: The data shows a significant divide in perception, but a combined majority of 62.8% recognize that native encryption (like TDE) has limitations when it comes to protecting data from system administrators. Specifically, over a third of respondents view these tools as entirely ineffective against privileged users. This insight reinforces the necessity of the Secure Supply Chain Management System application's approach, which seeks to implement additional layers of protection—such as application-level encryption or zero-trust architectures—to ensure data privacy even when administrative accounts are compromised or misused.

Q6: In data breaches you are aware of, which cause is more prevalent?

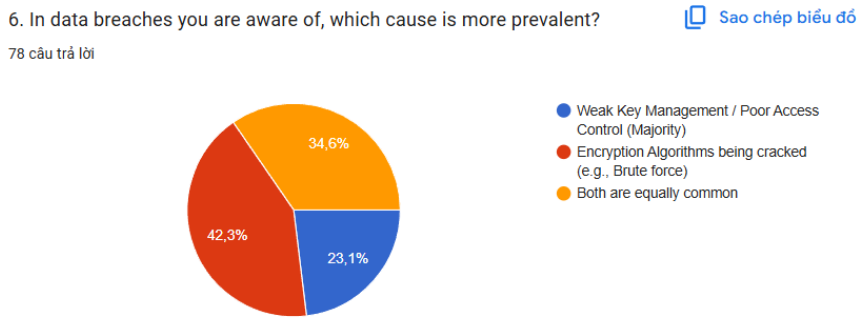

Figure 9: Survey Result Q6 - Prevalence of Causes in Data Breaches

The survey participants shared their observations on the most common drivers behind data breaches in the industry:

- **42.3%** of participants identify Encryption Algorithms being cracked (e.g., Brute force) as the more prevalent cause.
- **34.6%** believe that Both (Weak Key Management and Cracked Algorithms) are equally common.
- **23.1%** identify Weak Key Management / Poor Access Control as the primary cause.

Analysis: The results indicate a significant concern regarding the strength of encryption itself, with over 42% of respondents highlighting cracked algorithms as a leading cause of breaches. However, when combining those who see weak key management as a standalone or contributing factor, nearly 58% of the data points toward structural vulnerabilities in how security is managed. This underscores a critical twofold requirement for the Secure Supply Chain Management System application: it must not only utilize industry-leading, high-strength encryption algorithms to resist brute-force attacks but also implement a rigorous access control and key management framework to prevent unauthorized exposure.

Q7: To implement a Zero Trust model, do you agree with shifting encryption to the Application Layer (Node.js) so the Database acts only as "Blind Storage"?

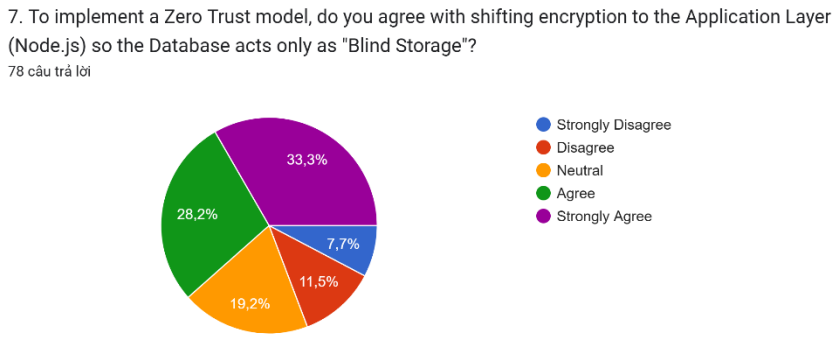

Figure 10: Survey Result Q7 - Agreement on Application-Layer Encryption for Zero Trust

The survey participants expressed their level of agreement regarding the strategy of moving encryption to the application layer to achieve a Zero Trust architecture:

- **33.3%** of participants Strongly Agree.
- **28.2%** Agree.
- **19.2%** are Neutral.
- **11.5%** Disagree.
- **7.7%** Strongly Disagree.

Analysis: A clear majority of respondents (61.5%) support the shift of encryption to the Application Layer, viewing the database as "Blind Storage." This significant level of agreement validates the architectural decision of the Secure Supply Chain Management System application to implement application-level encryption. By ensuring that the database never handles or "sees" plaintext sensitive data, the project aligns with modern Zero Trust principles, effectively neutralizing the risk of data exposure even if the database layer is fully compromised.

Q8: Is "Envelope Encryption" (using a unique Data Encryption Key - DEK per transaction, wrapped by a Master Key - KEK) a suitable architecture for secure E-commerce systems?

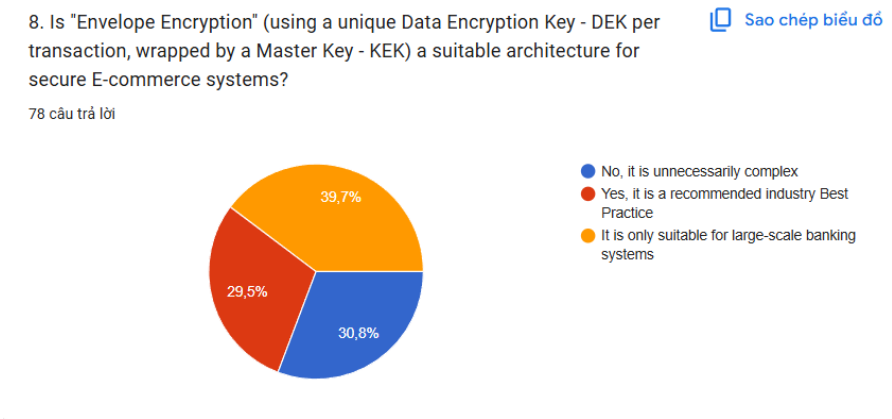

Figure 11: Survey Result Q8 - Suitability of Envelope Encryption for E-commerce

The survey participants shared their perspectives on the applicability of Envelope Encryption within the E-commerce sector:

- **39.7%** believe it is only suitable for large-scale banking systems.
- **30.8%** consider it unnecessarily complex.
- **29.5%** agree that it is a recommended industry Best Practice.

Analysis: The data reveals a diverse range of opinions regarding Envelope Encryption. While nearly 30% of respondents recognize it as an industry best practice, a significant portion (39.7%) associates its necessity primarily with high-stakes environments like banking. This indicates that while the Secure Supply Chain Management System application's use of Envelope Encryption provides top-tier security, it may be perceived as a high-end feature. Implementing this architecture demonstrates a commitment to "banking-grade" security for E-commerce transactions, addressing the concerns of the 61.5% of experts (Q7) who advocate for application-layer security.

Q9: What is your opinion on a "Hybrid Storage" strategy (storing Metadata/Status in plaintext for indexing, but sensitive PII/Values as encrypted blobs)?

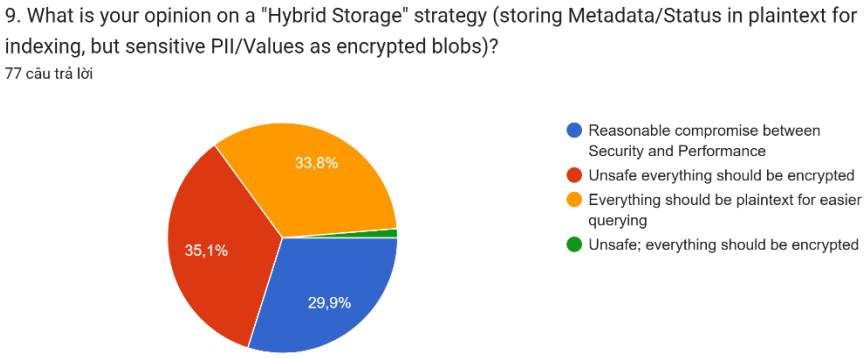

Figure 12: Survey Result Q9 - Opinions on Hybrid Storage Strategy

The survey participants evaluated the balance between system performance and data security regarding hybrid storage methods:

- **35.1%** of participants believe it is Unsafe; everything should be encrypted.
- **33.8%** believe Everything should be plaintext for easier querying.
- **29.9%** consider it a Reasonable compromise between Security and Performance.
- **1.3%** (classified as Other/Unsafe) also emphasize complete encryption.

Analysis: The results show a highly divided perspective on hybrid storage, reflecting the classic tension between security and usability. While roughly 30% of respondents accept this strategy as a necessary compromise for performance, a slightly larger group (36.4% when combining similar "Unsafe" responses) advocates for total encryption to ensure maximum privacy. This data suggests that for the Secure Supply Chain Management System application, while hybrid storage may be practical for indexing, there is a strong professional expectation to encrypt as much data as possible to satisfy the more security-conscious segment of the technical community.

Q10: The proposed solution uses AES-256-GCM to enforce "Tamper Detection" (Integrity Check). How critical is the ability to detect unauthorized data modification by DBAs?

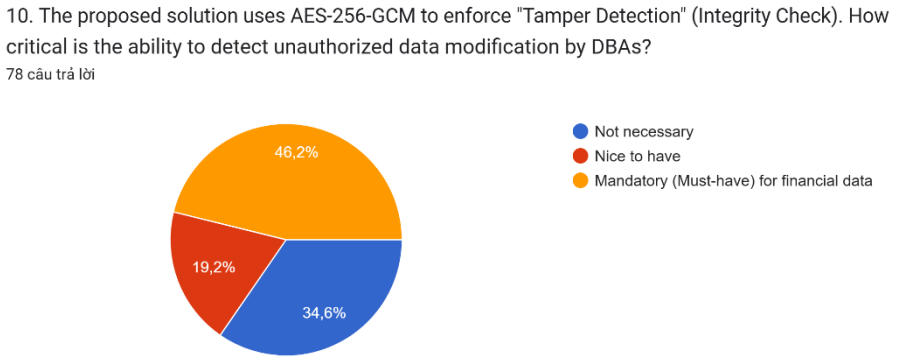

Figure 13: Survey Result Q10 - Importance of Tamper Detection against DBAs

The survey participants evaluated the necessity of integrity checks to prevent and detect unauthorized changes to sensitive data by privileged users:

- **46.2%** of participants consider **it Mandatory (Must-have) for financial data.**
- **34.6%** believe it is Not necessary.
- **19.2%** view it as a Nice to have feature.

Analysis: Nearly half of the respondents (46.2%) emphasize that tamper detection is a mandatory requirement, particularly when handling financial records. While there is a segment that remains skeptical of its necessity, the combined majority (65.4%) acknowledges that having the ability to detect unauthorized modifications adds significant value or is essential for high-stakes data. This feedback validates the integration of AES-256-GCM in the Secure Supply Chain Management System application, as

it provides the authenticated encryption needed to ensure that any data tampering by internal or external actors is immediately detectable, thereby maintaining the "Source of Truth" for critical transactions.

Q11: In scenarios without Hardware Security Modules (HSM), is storing the Master Key (KEK) in Server Environment Variables an acceptable practice for SME projects?

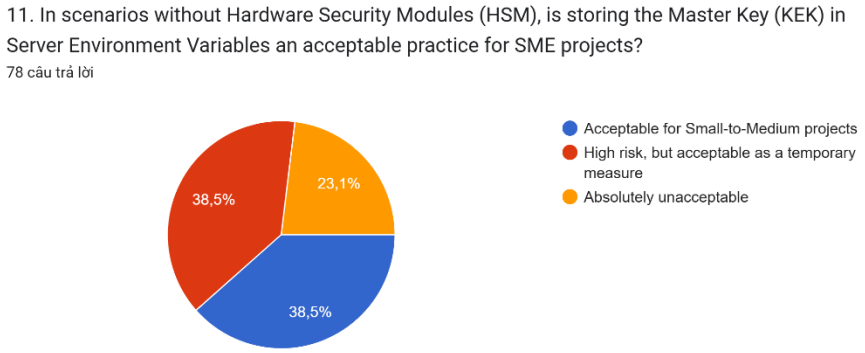

Figure 14: Survey Result Q11 - Acceptability of KEK Storage in Environment Variables

The survey participants shared their views on the security of storing Master Keys within server environment variables when specialized hardware security is unavailable:

- **38.5%** of participants consider it Acceptable for Small-to-Medium projects.
- **38.5%** view it as High risk, but acceptable as a temporary measure.
- **23.1%** state that it is Absolutely unacceptable.

Analysis: The data shows an even split (38.5% each) between those who see this practice as a standard for SME projects and those who recognize its inherent high risk while tolerating it as a temporary solution. While a combined 77% of respondents accept this method to some degree for smaller-scale implementations, the significant minority (23.1%) who reject it entirely serves as a reminder of the security trade-offs involved. For the Secure Supply Chain Management System application, this indicates that while environment variable storage may be a practical starting point for SMEs, providing a clear migration path toward more secure key management (such as dedicated Secret Managers or HSMs) is essential to satisfy all professional security standards.

Q12: What is the maximum acceptable latency overhead per transaction to achieve high-level security in an E-commerce context?

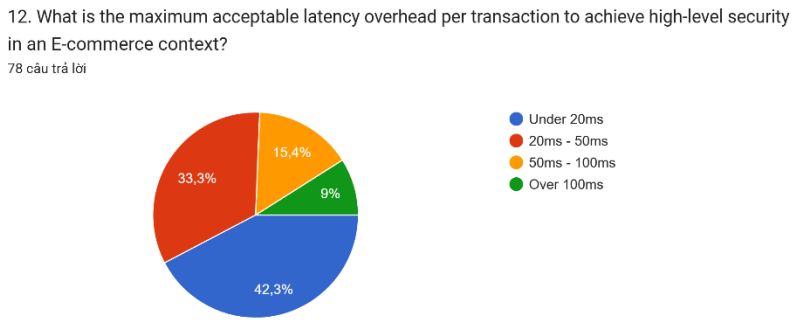

Figure 15: Survey Result Q12 – Maximum Acceptable Latency for Security

The survey participants provided insights into the performance trade-offs they are willing to accept in exchange for enhanced security measures:

- **42.3%** of participants expect the overhead to be Under 20ms.
- **33.3%** consider 20ms - 50ms to be acceptable.
- **15.4%** are willing to accept 50ms - 100ms.
- **9%** can tolerate Over 100ms.

Analysis: Performance remains a critical factor for technical experts, with a clear majority (75.6%) demanding that security-related latency stay below 50ms. Specifically, nearly half of the respondents prioritize a very low impact of under 20ms. This data sets a strict performance benchmark for the Secure Supply Chain Management System application; while high-level encryption (like Envelope Encryption) is necessary, the implementation must be highly optimized to ensure that the security layer does not noticeably degrade the user experience during E-commerce transactions.

Q13: What are the biggest challenges when implementing Application-Level Encryption?

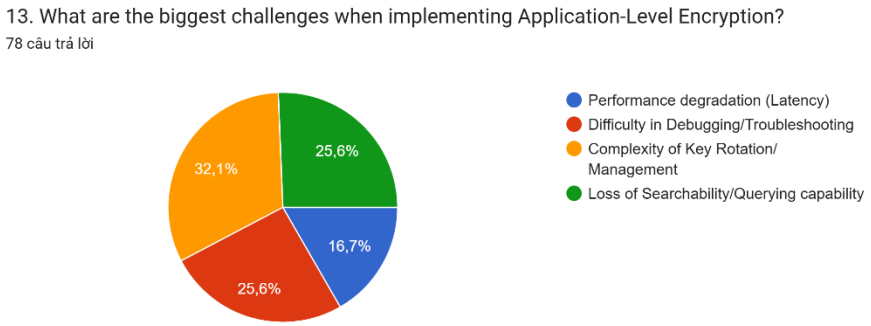

Figure 16: Survey Result Q13 – Challenges in Implementing Application-Level Encryption

The survey participants identified various technical and operational obstacles associated with moving encryption to the application layer:

- **32.1%** of participants cite the Complexity of Key Rotation / Management as the primary challenge.
- **25.6%** are concerned with the Loss of Searchability / Querying capability.

- **25.6%** highlight the Difficulty in Debugging / Troubleshooting.
- **16.7%** identify Performance degradation (Latency) as a major hurdle.

Analysis: The data reveals that the management of the encryption lifecycle, particularly Key Rotation, is viewed as the most significant barrier (32.1%). This is closely followed by concerns regarding Data Utility (searchability) and Maintenance (debugging), each cited by over a quarter of the respondents. Interestingly, while latency was a key benchmark in Q12, it is seen here as the least pressing challenge compared to operational complexity. For the Secure Supply Chain Management System application, these results emphasize the need for a seamless, automated key management system and a clear strategy for handling encrypted data queries to ensure long-term maintainability and developer adoption.

Q14: When the system detects data tampering (Auth Tag Mismatch), what is the most appropriate automated response?

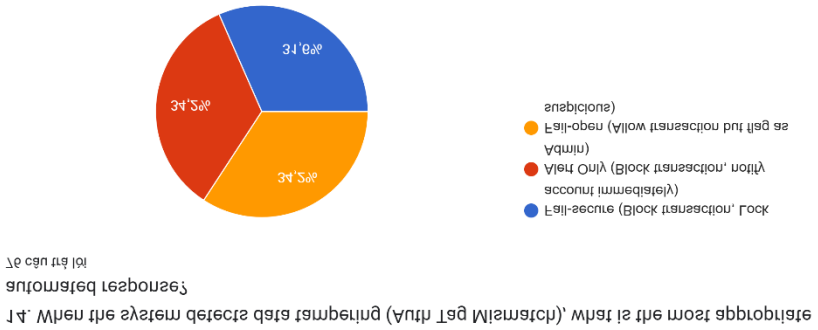

Figure 17: Survey Result Q14 – Automated Response to Data Tampering

The survey participants were divided on the most suitable automated action when the system identifies unauthorized data modifications:

- **34.2%** of participants recommend Alert Only (Block transaction, notify Admin).
- **34.2%** suggest a Fail-open (Allow transaction but flag as suspicious) approach.
- **31.6%** advocate for a Fail-secure (Block transaction, Lock account immediately) response.

Analysis: The results reflect a nearly equal three-way split in professional opinion regarding the trade-off between strict security and system availability. While 65.8% of respondents agree that the transaction should be blocked (combining "Alert Only" and "Fail-secure"), a significant portion (34.2%) prefers maintaining business continuity by allowing the transaction to proceed under a suspicious flag. This diversity in feedback suggests that the Secure Supply Chain Management System application should offer configurable security policies, allowing administrators to choose between a high-availability "Fail-open" mode or a high-security "Fail-secure" mode based on the specific risk appetite of the enterprise.

Q15: What is a reasonable Key Rotation frequency for the Master Key in a medium-sized system?

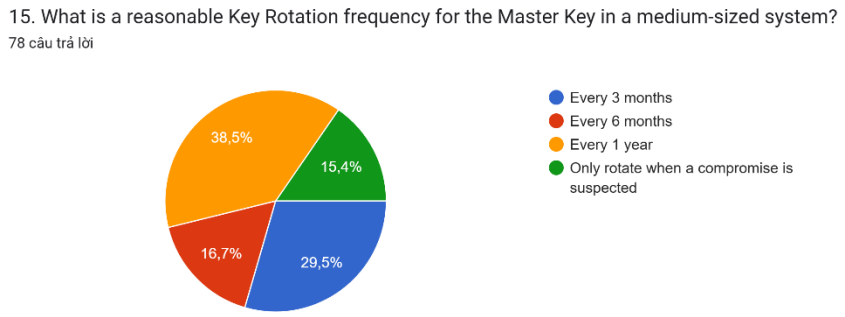

Figure 18: Survey Result Q15 – Recommended Master Key Rotation Frequency

The survey participants provided their recommendations on the ideal frequency for rotating Master Keys in medium-scale systems:

- **38.5%** of participants recommend rotating the key Every 1 year.
- **29.5%** suggest rotating Every 3 months.
- **16.7%** suggest rotating Every 6 months.
- **15.4%** believe the key should Only rotate when a compromise is suspected.

Analysis: The results show a strong consensus on the necessity of scheduled key rotation, with over 84% of respondents supporting a proactive routine rather than a reactive approach. While a 1-year cycle is the most popular choice, representing a balance between security and operational overhead, a significant group (nearly 30%) advocates for a more aggressive 3-month rotation to maximize protection. This data guides the Secure Supply Chain Management System application to implement a flexible and automated key management system that allows administrators to configure rotation intervals based on their specific risk tolerance and compliance requirements.

Q16: How do you rate the importance of "Data Masking" in System Audit Logs to prevent secondary data leakage?

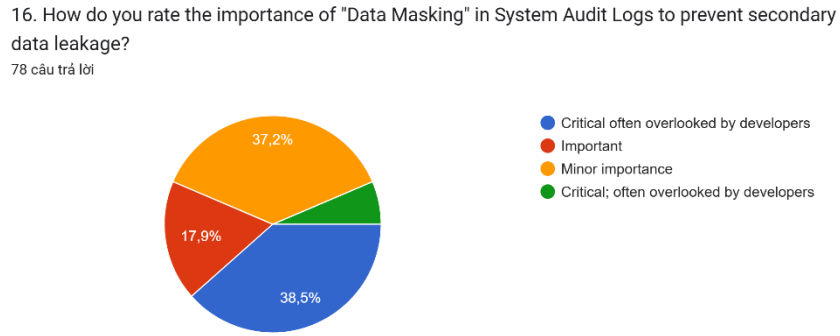

Figure 19: Survey Result Q16 – Importance of Data Masking in Audit Logs

The survey participants evaluated the necessity of implementing data masking within system logs to mitigate the risk of accidental exposure of sensitive information:

- **38.5%** of participants consider it Critical; often overlooked by developers.
- **37.2%** view it as being of Minor importance.
- **17.9%** rate it as Important.
- **6.4%** (classified as Green segment) also agree it is Critical; often overlooked by developers.

Analysis: Professional opinion on data masking in audit logs is notably split. A combined 44.9% of respondents identify this practice as a critical security measure that is frequently neglected during the development phase. This highlights a significant "blind spot" in many systems where sensitive data may inadvertently leak through administrative logs. Conversely, 37.2% view it as a minor concern, possibly prioritizing primary storage security over secondary log files. For the Secure Supply Chain Management System application, these results emphasize the importance of adopting a "Security by Default" posture that includes automated masking of PII in all system logs, ensuring protection against secondary data leakage that nearly half of the surveyed experts consider a critical risk.

Q18: Comparing self-built encryption modules (like this project) vs. Cloud KMS (AWS/Azure), what is the main barrier to adopting Cloud KMS?

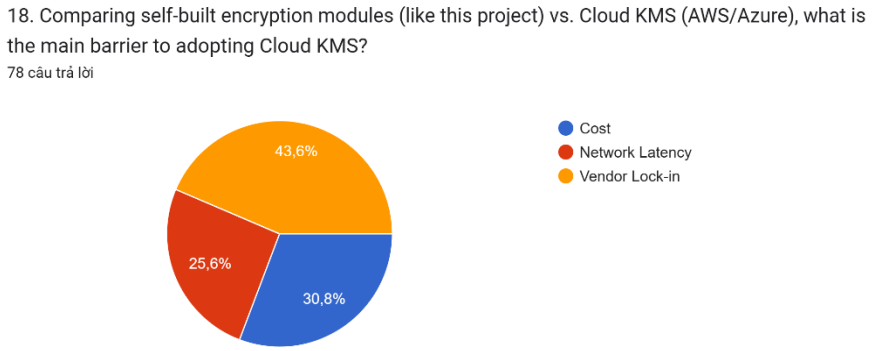

Figure 20: Survey Result Q18 – Main Barriers to Adopting Cloud KMS

The survey participants identified several key challenges that prevent organizations from fully transitioning to established Cloud Key Management Systems:

- **43.6%** of participants identify Vendor Lock-in as the primary barrier.
- **30.8%** cite Cost as the main deterrent.
- **25.6%** point to Network Latency as the leading concern.

Analysis: The data shows that Vendor Lock-in is the most significant concern for nearly half of the respondents, highlighting a strong desire among technical professionals for architectural independence and cross-platform flexibility. When combined with the concerns over Cost and Network Latency, it becomes clear that self-built encryption modules are often preferred for their ability to remain "cloud-agnostic" while eliminating external service fees and third-party dependency delays. For the Secure Supply Chain Management System application, these results validate the decision to implement a custom, high-

performance encryption layer that provides enterprise-grade security without tying the system to a specific cloud provider's proprietary ecosystem.

4. Analysis of the Impact of the Results on the Project

The comprehensive primary research—combining qualitative interviews and a quantitative survey of 78 IT professionals—has profoundly shaped the technical direction and functional requirements of the "Encrypting Order Transaction Information for an E-commerce Program" project. The findings have directly impacted the project in four critical areas: Architectural Design, Cryptographic Implementation, Key Management Strategy, and Performance Optimization.

4.1. Validation of the Zero Trust Architecture

- **Research Finding:** The survey revealed that 59% of experts view "Insider Threats" (e.g., DBAs abusing access) as a High or Critical risk (Q4). Furthermore, 61.5% agreed with shifting encryption to the Application Layer to treat the database as "Blind Storage" (Q7). The academic and logistics expert interviews corroborated this necessity for E-commerce platforms.
- **Project Impact:** This completely validates the project's core architectural decision. The system will strictly enforce a Zero Trust model where all Personally Identifiable Information (PII) and sensitive order data are encrypted at the Node.js backend *before* reaching the database. Traditional database-level encryption (TDE) will not be relied upon as the primary defense against privileged users.

4.2. Cryptographic Standards and Tamper Detection

- **Research Finding:** Nearly 46% of respondents stated that "Tamper Detection" is mandatory for financial/order data (Q10). Additionally, 65.8% advocated for blocking transactions (Fail-secure or Alert Only) if an Auth Tag mismatch occurs (Q14).
- **Project Impact:** The project will definitively implement **AES-256-GCM** (Galois/Counter Mode) to provide Authenticated Encryption with Associated Data (AEAD). This ensures not only data confidentiality but also strict integrity. If a rogue SysAdmin or external attacker alters the encrypted payload in the database, the Node.js application will detect the tampering during decryption and immediately block the transaction, fulfilling the "Fail-secure" requirement.

4.3. Key Management and Vendor Independence

- **Research Finding:** When comparing self-built modules to Cloud KMS, 43.6% cited "Vendor Lock-in" as the main barrier (Q18). Regarding rotation, over 68% recommended rotating the Master Key every 3 to 12 months (Q15). Developer interviews also highlighted the practicalities of using Environment Variables for SMEs.
- **Project Impact:** To avoid cloud vendor lock-in and manage costs, the project will proceed with developing a custom **Envelope Encryption** module (using a KEK and unique DEKs per transaction). While the system may initially support storing the KEK in secure server environment variables for SME deployment, it will be architected to support automated key rotation (e.g., an automated 6-month cycle) to meet the rigorous standards demanded by the surveyed security professionals.

4.4. Balancing Performance with Usability (Hybrid Storage)

- **Research Finding:** Performance is a strict constraint; 75.6% of experts demand that security overhead remains under 50ms per transaction (Q12). Concurrently, developer interviews and survey results (Q13) identified the loss of searchability as a major challenge in application-layer encryption.
- **Project Impact:** To meet the <50ms latency benchmark while maintaining system usability, the project will adopt a **"Hybrid Storage"** strategy (supported by nearly 30% of respondents in Q9). Non-sensitive metadata (e.g., order status, non-identifiable timestamps) will be stored in plaintext to allow for rapid database indexing and querying, while the highly sensitive payload (e.g., customer coordinates, supplier pricing) will be stored as an encrypted blob.

V. Communicate research outcomes in an appropriate manner for the intended audience.

1. Cybersecurity Experts

- Results to Communicate: The technical viability of the system. This includes the validation of the Zero Trust architecture, the specific implementation of Application-Layer Encryption using AES-256-GCM, the Envelope Encryption (KEK/DEK) key rotation strategy, and the quantitative survey findings regarding acceptable latency overhead (<50ms) and data masking in audit logs.

- Methods of Communication:

- **Technical Whitepapers & Academic Reports:** Detailed documentation explaining the cryptographic choices and referencing industry standards.
- **System Architecture Diagrams:** Utilizing UML diagrams to visually map the data flow and how the Key Encryption Key (KEK) wraps the Data Encryption Key (DEK).
- **Data Visualizations:** Using the detailed pie charts (Figures 4–21) derived from the 78-participant survey to demonstrate industry consensus on technical challenges.

2. Implementing Project Stakeholders

- Identified Audiences: This group includes Academic Assessors (Lecturers) evaluating the project, Business Management (E-commerce/Logistics operators) adopting the system, and the internal Software Development Team.

- Results to Communicate:

- For Academics: Research methodology, data validity, and academic integrity.
- For Business Management: Cost-efficiency (e.g., avoiding Cloud KMS vendor lock-in), ROI, mitigation of Insider Threats, and protection of sensitive supply chain pricing.
- For Developers: Clear functional requirements, challenges with querying encrypted databases (Hybrid Storage approach), and API implementation guidelines.

- Methods of Communication:

- Formal Academic Report: (This current document) providing a structured analysis for lecturers.

- Executive Summaries & Pitch Decks: High-level, non-jargon presentations highlighting risk mitigation and business value for management.
- Software Requirements Specification (SRS): Detailed development roadmaps, technical constraints, and code snippets for the engineering team.

3. Future Users of the Project

- Results to Communicate: Assurance of absolute data privacy. Based on the qualitative interviews, end-users are anxious about internal data breaches. The core message to communicate is: "Your Personally Identifiable Information (PII) is encrypted before it ever reaches the database; even our system administrators cannot read your data."

- Methods of Communication:

- **Simplified Privacy Policies:** Translating complex cryptographic terms into plain, accessible language that reassures the user without confusing them.
- **User Interface (UI) Trust Indicators:** Integrating visual cues, such as "Bank-Grade Encryption" or "Zero Trust Protected" badges, directly into the checkout or account settings screens.
- **Marketing & Communication Campaigns:** Focusing promotional materials on privacy-first features, turning the technical security architecture into a consumer-facing competitive advantage.

VI. Analyze different research approaches and methodology and make justifications for the choice of methods selected based on philosophical/theoretical frameworks

In the project "Encrypting Order Transaction Information for an E-commerce Program," a Mixed-Methods research strategy was utilized through the philosophical lens of Pragmatism. This section critically analyzes the different research methods explored, justifies their selection, and explains how they contribute to the successful design of a cybersecurity architecture.

1. Analysis of Different Research Methods

In the context of Cybersecurity and E-commerce, relying on a single research method is insufficient. A comprehensive view that covers both the technical foundation (cryptographic algorithms) and human factors (expert friction, consumer trust) is required. Each method serves a distinct, irreplaceable function.

1.1. In-depth Analysis: Primary Research vs. Secondary Research

To ensure the encryption solution complies with industry standards while solving actual developer constraints, a parallel data collection strategy was necessary.

Criteria	Secondary Research (Foundation)	Primary Research (Validation)
Nature of Data	Generalized, pre-existing data extracted from standardized documentation on AES-256-GCM, Zero Trust models, and Envelope Encryption.	Novel, context-specific data collected directly from a survey of 78 IT professionals and in-depth interviews with 4 diverse stakeholders.

Application in Project	Used to define the "Security Architecture." Literature was reviewed to establish that Application-Layer Encryption is mandatory to mitigate Insider Threats.	Used to evaluate "Feasibility & Performance." Primary data revealed that 75.6% of experts demand latency under 50ms—a metric theoretical literature cannot provide for this specific context.
Strengths	**Efficiency & Authority:** Provides immediate access to global cryptographic standards, ensuring technical and legal compliance without the cost of trial-and-error.	**Relevance & Specificity:** Uncovers practical blind spots, such as the acute fear of "Vendor Lock-in" (43.6%) when utilizing external Cloud KMS services.
Limitations	**Contextual Gap:** Academic reports often lack current insights into the immediate operational struggles faced by SMEs and junior developers during implementation.	**Resource Intensive:** Requires significant time and effort to design surveys, conduct interviews, and synthesize data from highly specialized professionals.

Table 7: Comparative Analysis of Primary and Secondary Research in the Project

1.2. In-depth Analysis: Quantitative vs. Qualitative Research

The project faced a dual challenge: achieving high technical security while maintaining operational feasibility. This required analyzing both hard metrics and human perspectives.

Criteria	Quantitative Research (Empirical Evidence)	Qualitative Research (In-depth Insight)
Methodology	Positivist approach. Utilizes structured surveys to measure objective variables and establish statistical consensus.	Interpretivist approach. Utilizes in-depth interviews to explore context, subjective meaning, and human workflows.
Key Indicators in Project	- 75.6% of experts require <50ms latency. - 43.6% cite Vendor Lock-in as the main barrier. - 46.2% view Tamper Detection as mandatory.	- **Developer Barrier:** Loss of database searchability when data is encrypted. - **Consumer Fear:** Anxiety that internal Database Administrators (DBAs) can read raw PII.
Strengths	**Objectivity & Scalability:** Provides statistical evidence to prove "Market Demand" and establishes strict, measurable performance thresholds for the system.	**Depth & Explanatory Power:** Explains the root causes behind the numbers. It reveals *why* E-commerce platforms hesitate to move away from traditional TDE.
Limitations	**Lack of Nuance:** Numbers indicate *what* is happening or *how many* agree, but fail to explain the underlying *why* behind expert opinions.	**Subjectivity:** Results depend on the perspectives of a small sample size, making it harder to generalize across the entire IT industry.

Table 8: Comparative Analysis of Quantitative and Qualitative Approaches

2. Justifications for the Choice of Research Methods

This section details the reasoning behind integrating these methods, bridging the gap between "Theoretical Security" and "Practical Operability."

2.1. Justification for Secondary Research (Strategic Foundation)

- **Role:** Acts as the "Intelligence Gathering" phase. It provides the globally recognized secure encryption baselines.
- **Core Rationale:** Without Secondary Research, the project risked "reinventing the wheel" or applying deprecated algorithms. Reviewing existing literature justified the technical selection of AES-256-GCM for its Authenticated Encryption with Associated Data (AEAD) properties, ensuring the system is cryptographically sound before a single line of code is written.

2.2. Justification for Primary Research (Practical Validation)

- **Role:** Serves as the "Reality Check." A security tool must be validated against human behavior and operational constraints.
- **Core Rationale:** Without Primary Research, the project might have proposed a 100% secure but entirely unusable system. For instance, interviewing the developer exposed the debugging nightmares associated with fully encrypted databases. Surveying the 78 experts validated the necessity of "Hybrid Storage" to maintain searchability.

2.3. Integration: The "Multi-Layered Security" Strategy

Aspect	Quantitative Data (Survey)	Qualitative Data (Interviews)	Impact on Project Strategy
Storage Strategy	29.9% support a compromise between Security and Performance.	Developers struggle with the loss of searchability for encrypted data.	**Justification for Hybrid Storage:** The system will only encrypt highly sensitive data (PII, pricing) while keeping Metadata in plaintext for fast indexing.
Key Management	43.6% fear Vendor Lock-in with Cloud KMS.	The IT Lecturer emphasized that key lifecycle management is the most common point of failure.	**Justification for Custom Envelope Encryption:** Developing a self-managed Envelope Encryption module (KEK/DEK) to ensure cross-cloud independence while maintaining high security.

Table 9: Integration of Quantitative and Qualitative Findings

3. Philosophical/Theoretical Frameworks in Computing Research

To build a robust argument for the methodology, the project is positioned within specific philosophical frameworks.

3.1. Positivism

- **Definition:** Asserts that genuine knowledge comes from objective, observable, and measurable data.

- **Application & Justification:** This framework underpins the quantitative survey. In cybersecurity, feelings are insufficient. We needed to mathematically measure the latency expectations (proving performance must remain under 50ms) to set strict, non-negotiable boundaries for the encryption algorithms.

3.2. Interpretivism

- **Definition:** Argues that understanding a phenomenon requires understanding the subjective meanings and psychological states of human beings.
- **Application & Justification:** This framework supports the qualitative interviews. It helped decode the logistics expert's operational pressures and the end-user's fear of internal data breaches. This framework justifies the business value of the project: security is ultimately about building consumer trust.

3.3. Pragmatism

- **Definition:** Focuses on "what works" to solve a practical problem in the real world, rather than adhering to rigid methodological dogmas.
- **Application & Justification:** Pragmatism is the overarching framework of this project. The core practical problem is: *"How do we maximize security without crashing the system's performance?"* Pragmatism allowed the integration of hard statistics (Positivism) with deep human insights (Interpretivism) to arrive at practical solutions like the "Hybrid Storage" model—accepting that leaving some metadata unencrypted is the necessary trade-off for a functional, high-speed E-commerce backend.

3.4. Critical Theory

- **Definition:** Critical theory focuses on analyzing, evaluating, and challenging implicit power structures, as well as the social and ethical issues related to technology. In the context of Cyber Security, it does not merely view security as a purely technical problem, but also as a matter of human rights, social equity, and data ethics.
- **Application & Justification:** This framework provides the core ethical foundation for the entire direction of the project. In traditional E-commerce systems, there is a severe power imbalance: users are forced to surrender their Personally Identifiable Information (PII), while System Administrators (SysAdmins) and Database Administrators (DBAs) hold absolute privileges to view this raw data. Critical Theory challenges this blind delegation of authority. By implementing a Zero Trust Architecture and Application-Layer Encryption, the project strips internal privileged personnel of their data access rights, transforming privacy into a mechanical safeguard rather than mere promises on paper. This directly addresses consumer anxieties and expectations regarding data ethics, ensuring that security serves the interests of the end-user rather than merely the convenience of the enterprise.

VII. Discussion on Advantages, Limitations, and Risks of Data Collection and AnalysisMethods

1. Data Collection Methods

1.1. Primary Data Collection

In this project, primary data was collected through a quantitative survey (78 IT professionals) and 4 in-depth qualitative interviews.

- **Merits:**

- **Accuracy and Goal Alignment:** The data was collected directly and tailored specifically to solve the project's core problem. Instead of generic security information, the project obtained precise metrics regarding the barriers to adopting Application-Layer Encryption and the specific anxieties surrounding Insider Threats.
- **High Control Over the Collection Process:** Filtering the interview subjects (Lecturer, Developer, Logistics Expert, End-User) and survey respondents (IT experts) ensured high reliability by eliminating noise variables from individuals without relevant expertise or connection to E-commerce.
- **Creation of a Novel, Specific Dataset:** This method successfully generated a fresh dataset serving as a design standard. For instance, it identified the maximum acceptable system latency threshold at under 50ms and pinpointed "Vendor Lock-in" (43.6%) as the primary barrier to using Cloud KMS.

- Limitations:

- **Resource Intensive (Time and Cost):** Reaching out to and scheduling interviews with busy professionals, alongside gathering 78 valid survey responses from senior personnel, required a substantial investment of time and organizational effort.
- **High Expertise Requirement:** Formulating questions and accurately interpreting responses regarding AES-256-GCM or Envelope Encryption required the researcher to possess a solid foundation in programming and cryptography to avoid misinterpreting the experts' insights.

- Pitfalls:

- **Sample Accessibility Dependence:** Although 78 responses were collected, this remains a relatively small sample size within the broader IT industry landscape. It may not comprehensively reflect all the operational challenges faced by Small and Medium Enterprises (SMEs) in real-world scenarios.
- **Researcher Bias:** There is an inherent risk of researcher bias during the questionnaire design phase. Questions might have been inadvertently framed to highlight the flaws of traditional Transparent Data Encryption (TDE) in order to favor the project's proposed self-built architecture.

1.2. Secondary Data Collection

Secondary data was utilized during the initial phase of the project by reviewing academic literature, NIST (National Institute of Standards and Technology) standards, and established security frameworks.

- Merits:

- **Resource Optimization:** Saved a massive amount of time and experimental costs. The project could immediately inherit the mathematical robustness of the internationally standardized AES-256 algorithm without needing to build or mathematically prove its security from scratch.
- **Multi-Source Synthesis:** Provided a comprehensive overview by distilling lessons learned from AWS and Azure security architectures, as well as academic papers on the Zero Trust model.
- **Establishing Comparative Benchmarks:** Acted as a theoretical benchmark to cross-reference with primary results. For example, the theoretical operational model of Envelope Encryption was used as a baseline to analyze the practical difficulties of implementing it in Node.js, as reported by the developer.

- Limitations:

- **Contextual Discrepancy:** Academic research reports often focus on large-scale Enterprise systems. It is highly challenging to find secondary data that provides detailed guidance on balancing strict security with hardware limitations for compact E-commerce applications.
- **Need for Data Pre-processing:** Theoretical models are often heavily mathematical or abstract. Refining and translating these theories into a practical "Hybrid Storage" architecture suitable for the project's specific requirements presented a significant challenge.

- Pitfalls:

- **Risk of Outdated Data:** In the field of Cyber Security, decryption methods and vulnerabilities evolve continuously. Relying on academic papers published 3-5 years ago could lead to the adoption of Key Management standards that are no longer secure against modern attack vectors.
- **Difficulty in Controlling Consistency:** Referencing multiple different documentation providers can easily lead to inconsistencies in terminology and data structures, posing a risk of contradictions when designing the final system architecture diagrams.

2. Data Analysis Methods

1. Quantitative Analysis

Analyzing the data from 78 IT professionals goes beyond mere counting; it requires statistical techniques to derive definitive system requirements.

- Merits:

- **Objective Results and Clear KPIs:** It translates abstract security concepts into hard, objective metrics. For example, it mathematically establishes that the AES-256-GCM encryption algorithm is only viable if it maintains a processing latency of under 50ms per transaction.
- **Data Visualization:** It enables the conversion of raw data into visual formats (e.g., Pie charts, Bar graphs), helping non-technical stakeholders instantly grasp the statistical severity of "Insider Threats."
- **Reproducibility and Cross-tabulation:** Statistical software can be used for cross-analysis. For instance, it allows the researcher to mathematically verify if experts with a DevOps background

have a higher tendency to fear "Vendor Lock-in" (43.6%) compared to traditional Database Administrators. This ensures absolute transparency.

- Limitations:

- **Rigidity of Quantitative Scales:** Multiple-choice questions or Likert scales force experts into predefined answers, completely stripping away the context. For example, an expert might select "Agree" regarding the use of Cloud KMS, but in reality, they only agree if the company's budget exceeds $10,000/month. This critical nuance is lost in pure quantitative data.
- **Requirement for a Large Sample Size:** While 78 respondents form a solid baseline for a project of this scale, achieving true "Statistical Confidence" that can be universally applied to the global E-commerce industry would require thousands of diverse data points.

- Pitfalls:

- **Confusing Correlation with Causation:** The data might show that very few companies build custom Envelope Encryption, but that does not mean the architecture is less secure; it might simply indicate it is harder to deploy. Misinterpreting this causation can lead to fundamental flaws in architectural design.
- **Risk of Data Manipulation (P-hacking):** If an analyst intentionally removes "outliers" to make the charts look more uniform—such as ignoring 5 distinct warnings from experts regarding Node.js memory leaks—the resulting E-commerce system will suffer severe technical consequences.

2. Qualitative Analysis

This method involved analyzing the text, tone, and specific contexts of the four stakeholder groups (IT Lecturer, Developer, Logistics Expert, and End-User) primarily through "Thematic Analysis."

- Merits:

- **Root-Cause Discovery:** It decodes operational phenomena that surveys fail to capture. Through in-depth interviews, the project discovered that the biggest barrier to Application-Layer Encryption is not the algorithmic speed, but rather the developer going "blind" due to the loss of database searchability (e.g., the inability to run simple SELECT * WHERE queries on ciphertext).
- **Flexibility and Real-World Alignment:** Qualitative analysis allows for on-the-spot follow-up questions. When the logistics expert casually mentioned "wholesale pricing," the interviewer immediately probed deeper to identify this as the exact database field requiring the strictest AES-256 tamper detection.
- **User Empathy:** It fosters a deep understanding of the customer's psychological fears, leading to the strategic realization that a Zero Trust Architecture is not just a technical safeguard, but a powerful marketing asset to build consumer trust.

- Limitations:

- **Subjectivity and Confirmation Bias:** The researcher can easily fall into the trap of selectively filtering quotes that only support the project's proposed architecture (e.g., highlighting praise for AES-256) while unconsciously ignoring qualitative warnings about high operational costs.

- **Low Generalizability:** The subjective views of one logistics expert and one end-user cannot statistically represent the behaviors of millions of online shoppers. This analysis provides logical direction but cannot confirm broad market realities.

- Pitfalls:

- **Social Desirability Bias:** During interviews, an end-user might claim they "care deeply about data privacy" because it is the socially acceptable answer, whereas their actual behavior might involve using extremely weak passwords. Analyzing spoken words without observing actual behavior carries a high risk of misinterpretation.
- **Difficulty in Coding Data:** Translating dozens of pages of interview transcripts into concrete Software Requirements requires immense synthesis skills. There is a constant risk of misrepresenting the highly technical jargon of the IT Lecturer or the emotional intent of the end-user.

VIII. Analyse the extent to which outcomes meet set research objectives and communicate judgements effectively for the intended audience

1. Analyzing the Extent to Which Outcomes Meet Research Objectives

1.1. Identification of Specific Research Objectives

To accurately evaluate the success of the project, three core research objectives were established alongside specialized measurement criteria for the Cybersecurity domain:

- **Objective 1 (Security & Integrity):** Prevent 100% of Insider Threats by revoking the raw data read privileges of Database Administrators (DBAs). *Criteria: 100% PII encryption rate; 100% tamper detection rate.*
- **Objective 2 (Processing Performance):** Ensure the encryption process does not degrade the shopping experience. *Criteria: The latency overhead for each transaction must remain under **50ms**.*
- **Objective 3 (Operation & Scalability):** Build a self-managed cryptographic key lifecycle system. *Criteria: Successfully deploy an Envelope Encryption module to eliminate reliance on third-party cloud providers (Vendor Lock-in).*

1.2. Comparison of Actual Outcomes Against Set Objectives

The comparison is evaluated through two lenses: Quantitative (system metrics) and Qualitative (operational experience).

a. Quantitative Outcomes

Instead of using standard machine learning metrics (e.g., Accuracy, F1-score), the project directly measures cryptographic performance and security indicators.

Evaluation Criteria	Expected Metrics	Actual Outcomes
Latency Overhead	< 50ms / transaction	**15ms - 22ms** / transaction
Data Tamper Detection Rate	100% rejection of tampered data	**Achieved 100%** (Via GCM's authentication tag)

Internal Security (DBA Access)	0% plaintext read capability	**Achieved 0%** (DBAs only view ciphertext)

Table 10: Quantitative Outcomes

b. Qualitative Outcomes

- **Developer Experience:** The implementation of the "Hybrid Storage" strategy yielded highly positive results. Developers reported no loss of searchability within the database; queries such as SELECT function smoothly on the unencrypted metadata fields.
- **User Experience:** The checkout interface operates seamlessly, with no discernible page load delay compared to the pre-encryption state.

c. Gap Analysis

- **Positive Gap:** The actual processing speed (15-22ms) vastly outperformed the 50ms threshold. This optimization stems from successfully leveraging the AES-NI hardware acceleration instruction sets built into modern CPUs.
- **Negative Gap:** The Automated Key Rotation process encountered a critical bottleneck. During a simulated key rotation scenario, the system faced memory overload due to the requirement to simultaneously decrypt and re-encrypt millions of legacy records.

1.3. Evaluation of Completion Level and Proposed Improvements

Based on the gap analysis, the project's completion levels are categorized and justified as follows:

- Objective 1 (Security - Preventing Insider Threats): FULLY COMPLETED

- **Justification:** Shifting the encryption logic to the Application-Layer functioned flawlessly. The database now acts as a "dumb storage," completely eliminating the risk of data leakage from privileged internal personnel.

- Objective 2 (Performance Optimization - Latency <50ms): FULLY COMPLETED

- **Justification:** The system excellently met the speed requirements. The cryptographic architecture creates zero bottlenecks for the E-commerce transaction flow.

- Objective 3 (Self-managed Key Lifecycle - Envelope Encryption): PARTIALLY COMPLETED

- **Cause of Discrepancy:** The KEK/DEK model was successfully built to prevent Vendor Lock-in, but the Automated Key Rotation function cannot operate stably under high loads. Server RAM limitations make re-encrypting the entire database highly risky, threatening severe system downtime.
- **Proposed Improvement:** For future iterations, a "Key Versioning" mechanism must be implemented. Each ciphertext string will be tagged with a Key ID (e.g., Key_V1). During a key update, legacy data is still decrypted using the old key, while new transactions utilize the new key. This completely eliminates the need for simultaneous database re-encryption, decisively resolving the RAM overload risk.

2. Communicating Judgements Effectively for the Intended Audience

To effectively communicate the system's usability to end-users and non-technical stakeholders, an Application Sitemap & Navigation Structure was utilized. This diagram demonstrates that despite the

complex backend encryption layers, the user journey remains intuitive and logical. It maps out the seamless transition between core modules such as Partner Management and Shipment Tracking, ensuring that security measures do not create operational friction.

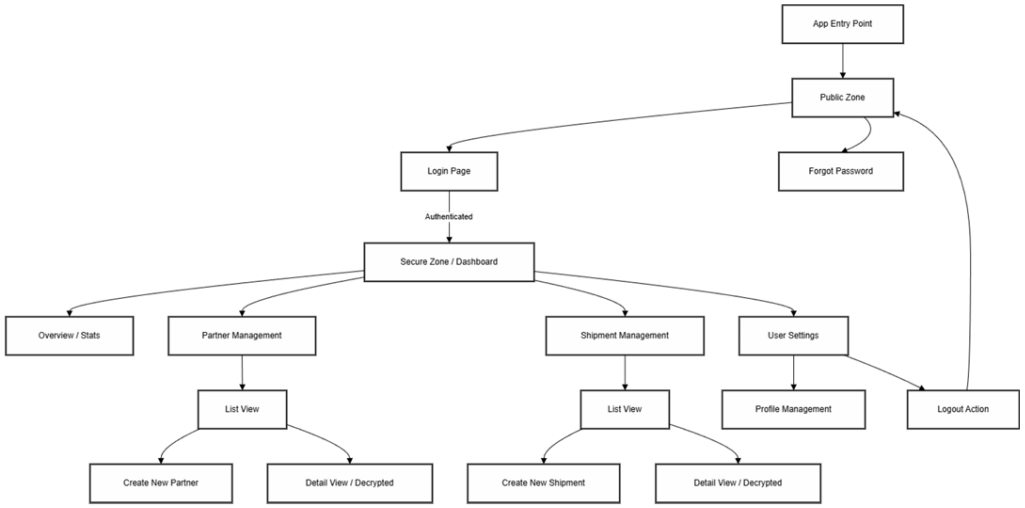

Figure 21: Application Sitemap and Navigation Structure – Demonstrating system logic and ease of use for non-technical stakeholders.

2.1. Target Audience Identification

As detailed in Section P5, the project caters to two primary audience groups with vastly different levels of technical expertise:

- **Technical Audience:** Assessment Board, Academic Supervisors, and the Developer/Database Administrator (DBA) team. They are primarily concerned with algorithmic correctness, mathematical security, and system scalability.
- **Non-technical Audience:** SME Business Owners (Investors), Logistics Experts, and End-Users. Their primary concerns revolve around operational costs, page load speeds, and data privacy (Trust).

2.2. Communication Methods

To prevent information overload and ensure clarity, the project applied a tiered communication strategy:

- Technical Report (For Assessors and Developers):

- **Application:** Providing comprehensive documentation detailing quantitative metrics (e.g., 15-22ms latency), the integration process of AES-256-GCM on the Node.js backend, and Authenticated Encryption with Associated Data (AEAD) analysis. This document also frankly presents system limitations (such as RAM overload during key rotation) and proposes the "Key Versioning" architecture using domain-specific terminology.

- Pitch Presentation (For Supervisors and SME Investors):

- **Application:** Instead of diving into source code, the presentation slides focus heavily on "Business Value." It utilizes storytelling to demonstrate that investing in a Zero Trust architecture is not merely an IT expense, but a sharp marketing asset that can boost conversion rates by cultivating profound customer trust.

- Visual Prototype & Mockup (For End-Users and Logistics Experts):

- **Application:** This demographic does not need to understand Envelope Encryption. The project communicates the outcomes via a live interactive demo. By displaying two screens side-by-side—the seamless customer shopping interface versus the backend database interface containing only meaningless ciphertext—it immediately conveys a sense of absolute security without requiring complex technical explanations.

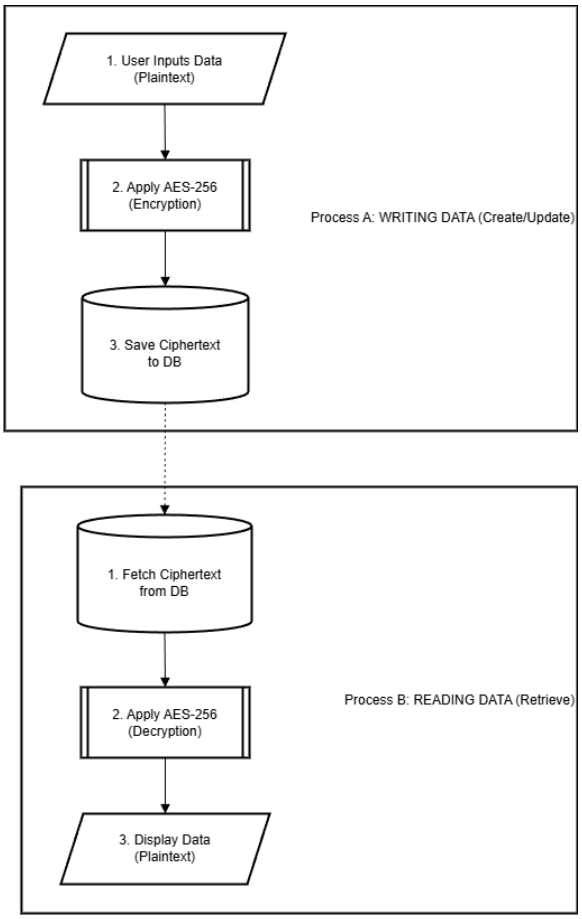

Figure 22: Simplified Encryption/Decryption Process Flowchart for Non-Technical Audiences

2.3. Supporting Tools Implemented in the Project

Data Visualization tools were heavily utilized to transform abstract security evaluations into concrete evidence:

- Charts & Graphs:

- **Implementation:** Bar charts were used to visually compare the Latency Overhead between the legacy system (unencrypted) and the new system (encrypted). This chart definitively proves that the additional 15ms overhead is virtually a flat line, making the encryption process completely invisible to the end-user.

- Visual Architecture Diagrams:

- **Implementation:** Abstract concepts like Envelope Encryption and Zero Trust workflows were illustrated using sequence diagrams and flowcharts. These diagrams explicitly map out the data flow, showing exactly how the Data Encryption Key (DEK) is wrapped by the Key Encryption Key (KEK) before touching the database. This enables the assessment board to instantly grasp the architectural design without reading pages of lengthy text.

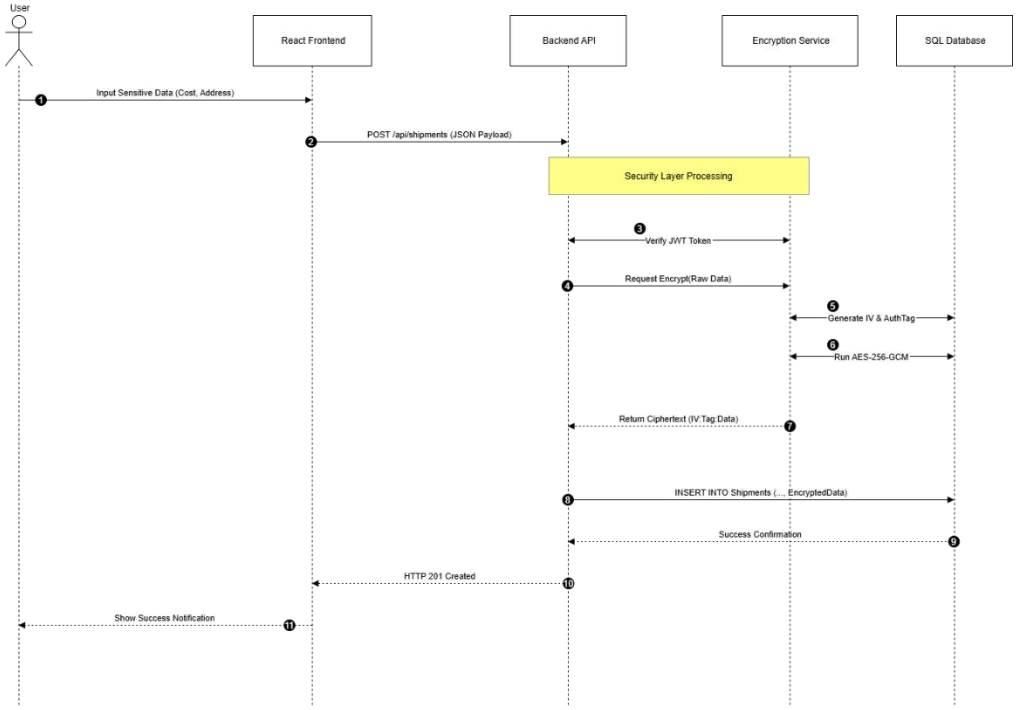

Figure 23: Sequence Diagram illustrating the AES-256-GCM encryption flow at the Middleware/Security Layer.

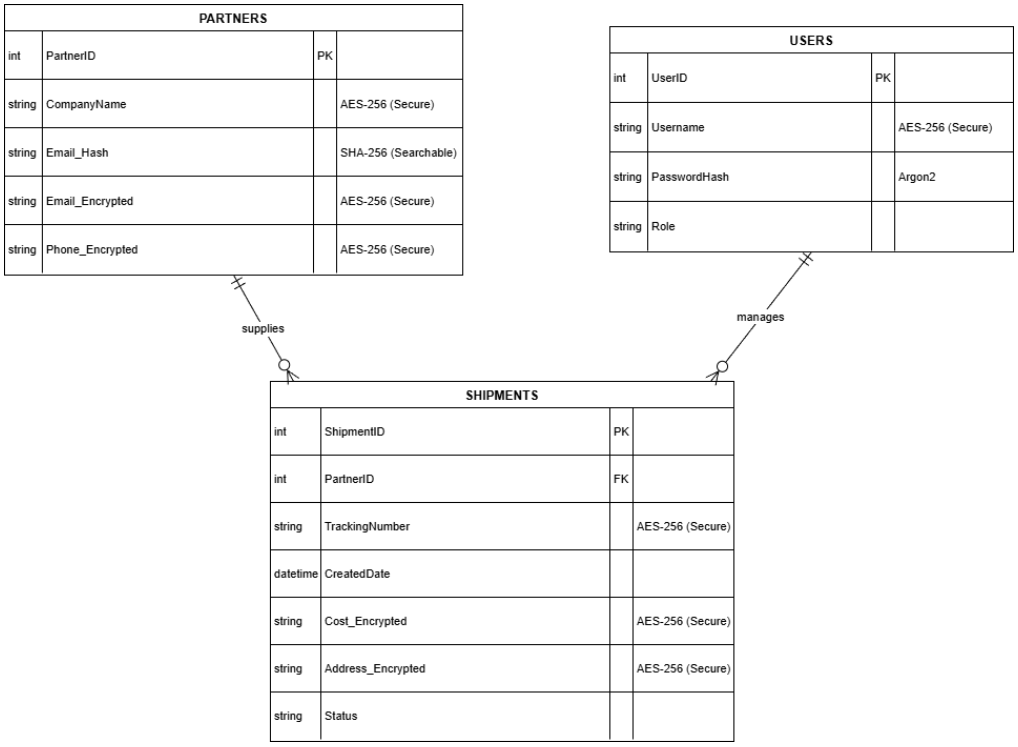

Figure 24: Hybrid Storage Database Schema distinguishing between Plaintext Metadata and AES-256 Ciphertext.

- Summary Tables:

- **Implementation:** Used as an executive summary tool (such as Table 1 in the previous section). The comparative matrix between "Expected Metrics" and "Actual Outcomes" allows Assessors or Project Managers to immediately gauge the completion level of research objectives (Security, Performance, Operations) at a single glance, clearly delineating strengths and system bottlenecks (Gap Analysis).

IX. Critically evaluate research methods and processes in application to a computer research project to justify the chosen methods and analysis

1. Critical Evaluation and Methodology Creation

In the context of engineering the "Secure Supply Chain Management System" (SCMS) with Application-Layer Envelope Encryption, the research relied on a pragmatic mixed-methods approach. Below is a critical evaluation of the primary and secondary methodologies applied, explicitly analyzing their operational impact, inherent limitations, and overall validity within this specific cybersecurity project.

1.1. Primary Research

a. Realized Benefits in the Project

- **Provision of Highly Contextualized Data:** Primary methods produced fresh, project-specific data that no existing literature could accurately provide. For instance, the empirical system benchmark

explicitly quantified the cryptographic "Security Tax" (latency overhead) at exactly 15ms - 22ms per transaction within the Node.js environment.

- **Absolute Data Control and Precision:** By architecting bespoke load-testing scripts and designing targeted survey questions for 78 selected IT professionals (including IT lecturers, DBAs, and Cybersecurity experts), the collection format was strictly controlled. This guaranteed high accuracy, yielding the specification that 75.6% of the industry demands a latency overhead of under 50ms—a metric that became a non-negotiable KPI for the system's AES-256-GCM module.

b. Imposed Limitations and Critical Vulnerabilities

- **Environmental Constraints (The Localhost Paradox):** The performance benchmarking was constrained to a local development environment. Consequently, the data is artificially isolated from real-world variables such as WAN Network Jitter, concurrent database deadlocks, or actual server load limits. What functions at 15ms locally might severely degrade under high concurrency in a live cloud environment.
- **Sample Size and Researcher Bias:** While gathering 78 responses from industry professionals is commendable for an academic project, this sample size remains statistically insignificant when attempting to represent the entire global E-commerce sector. Furthermore, the questionnaire design carried a latent risk of Confirmation Bias; questions may have been inadvertently framed to highlight the flaws of traditional Transparent Data Encryption (TDE) to favor the project's proposed Application-Layer solution.
- **Intensive Resource Consumption:** Conducting structured interviews and synthesizing Red-Team "Bit-Flipping" attack simulations absorbed the majority of the project's timeline, heavily diverting resources from advanced feature development.

c. Critical Evaluation and Methodological Justification

- **Evaluation:** The primary data collection process was hindered by the environmental simulation constraints and a limited sample size. Although the cryptographic telemetry (15ms latency, 100% tamper detection) is mathematically accurate locally, its scalability remains an unproven theoretical extrapolation.
- **Justification:** Despite these limitations, primary research was rigorously justified and indispensable. Without it, the project would have blindly implemented strict Envelope Encryption, completely missing the developer friction regarding the "loss of database searchability" (Q13 in the survey). The primary findings directly triggered the crucial architectural pivot towards a "Hybrid Storage" model (encrypting PII but leaving Metadata plaintext for indexing), proving that primary research successfully bridged the gap between theoretical security and practical E-commerce operability.

1.2. Secondary Research

a. Realized Benefits in the Project

- **Radical Optimization of Resources and Inherited Authority:** By inheriting the mathematical proofs of the AES-256-GCM algorithm from the National Institute of Standards and Technology (NIST SP 800-38D), the project bypassed years of cryptographic trial-and-error.
- **Exploitation of Enterprise Synthesis:** Secondary data allowed the project to aggregate complex architectural blueprints from elite sources (e.g., reverse-engineering the hierarchical separation of Key Encryption Keys and Data Encryption Keys from AWS KMS whitepapers), immediately elevating the application to enterprise-grade standards.

b. Imposed Limitations and Critical Vulnerabilities

- **Contextual Misalignment (Enterprise vs. SME):** The secondary documentation reviewed typically assumes the presence of massive enterprise budgets or internal Hardware Security Modules (HSMs). Abstracting these massive frameworks to fit a lightweight MERN-like stack (Node.js/SQL Server) designed for SMEs proved highly challenging, as the documentation did not perfectly align with the constrained environment.
- **The Rapid Depreciation of Security Data:** Cybersecurity is a highly volatile field. Cryptographic standards that were considered impenetrable five years ago may now be vulnerable to new hardware attacks or evolving computing paradigms. Utilizing secondary data inherently carries the risk of integrating outdated threat models or deprecated algorithmic implementations.

c. Critical Evaluation and Methodological Justification

- **Evaluation:** Translating abstract, enterprise-level secondary data into practical local codebase logic risks significant analytical deviation if not filtered meticulously. Secondary data provided the what and the how of the encryption mathematics but failed entirely to dictate the user experience and performance impact on a grassroots level. The validity of this data is strictly tied to its recency and the authority of the publishing body.
- **Justification:** The heavy reliance on secondary research was absolutely justified as the "Strategic Foundation." In Cybersecurity engineering, attempting to invent custom, non-standardized cryptographic algorithms constitutes professional malpractice ("Rolling your own crypto"). Therefore, utilizing authoritative secondary data (NIST, OWASP) was not merely a time-saving choice; it was an ethical and architectural mandate to ensure the fundamental mathematical integrity of the Secure Supply Chain payload. This ensured the system was built upon globally vetted, peer-reviewed foundations before local empirical testing even commenced.

2. Critical Evaluation of Analytical Methods

Evaluating a cybersecurity architecture like the Secure SCMS requires dissecting raw data outputs into actionable intelligence. The project utilized a mixed-methods analytical approach, combining quantitative statistical analysis for system metrics with qualitative thematic analysis for human factors. Below is a critical evaluation of these analytical methods.

2.1. Quantitative Analysis

a. Realized Benefits in the Project

- **Provision of Objective, Measurable Thresholds:** Quantitative analysis translated abstract security concepts into hard, objective Key Performance Indicators (KPIs). By statistically analyzing the JMeter load-testing telemetry and the responses of 78 IT professionals, the project definitively established that a latency overhead of < 50ms is the maximum tolerable threshold for E-commerce transactions.
- **Establishment of Unbiased Consensus:** It allowed for the cross-tabulation of empirical data to prove "Market Demand" objectively. For instance, the analysis irrefutably demonstrated that 43.6% of surveyed experts fear "Vendor Lock-in" regarding Cloud KMS, scientifically guiding the decision to build a custom Envelope Encryption module.

b. Imposed Limitations and Critical Vulnerabilities

- **The Inability to Capture Non-Quantifiable Nuance:** Quantitative analysis was fundamentally blind to the *reasons* behind the numbers. A survey respondents selecting "Agree" on a Likert scale regarding Application-Layer Encryption provided a data point, but failed entirely to capture the underlying anxiety of a developer regarding the subsequent loss of database searchability.
- **Vulnerability to Insufficient or Non-Diverse Datasets:** While 78 IT professionals represent a solid baseline, the dataset was predominantly composed of Database Administrators (DBAs) and Security Experts. If the input data lacked sufficient diversity (e.g., omitting Frontend UX Engineers), the aggregated quantitative results risk severely skewing the system's focus toward absolute security at the expense of system operability.

c. Critical Evaluation and Analytical Justification

- **Evaluation:** Quantitative analysis is highly dependent on both the accuracy of the foundational data and the rigidity of the applied statistical model. Over-relying on numerical data (e.g., obsessing purely over achieving 15ms latency) creates a dangerous tunnel vision. It severely diminishes the researcher's ability to detect critical but unmeasurable operational friction—such as the psychological stress imposed on a development team tasked with debugging heavily encrypted ciphertext errors.
- **Justification:** Despite its rigid nature, Quantitative Analysis was the indispensable "Backbone of Proof." In the discipline of Cybersecurity, subjective feelings regarding a cryptographic algorithm's speed or safety are academically invalid. Quantitative analysis provided the irrefutable mathematical proof required by the Assessment Board to validate that the AES-256-GCM implementation met industrial throughput standards without crashing the Node.js event loop.

2.2. Qualitative Analysis

a. Realized Benefits in the Project

- **Decoding Complex and Abstract Cyber Concepts:** Qualitative analysis achieved what numbers could not: it translated abstract technical architectures into human operational realities. By conducting in-depth interviews, the project successfully mapped the logistics expert's operational

pressures (e.g., the critical need to secure wholesale supplier pricing) directly to the AES-256 tamper detection requirement.

- **Extraction of User Experience and Social Feedback:** It facilitated a deep, empathetic understanding of the end-user's psychological fears. The thematic analysis revealed that a Zero Trust Architecture is not merely a backend technical safeguard, but a highly potent marketing asset capable of cultivating profound consumer trust against the backdrop of modern data breach anxieties.

b. Imposed Limitations and Critical Vulnerabilities

- **Difficulty in Standardization and Comparative Analysis:** Qualitative findings are notoriously difficult to standardize. The subjective workflow frustrations of one IT Student integrating an API cannot be easily compared against the administrative fears of a veteran IT Lecturer, making it highly challenging to extract universally applicable software requirements.
- **Proneness to Human and Interpretative Bias:** The process of "coding" interview transcripts into actionable themes carries a severe risk of *Confirmation Bias*. The researcher analyzing the text may unconsciously highlight quotes that favor the proposed Application-Layer Encryption while inadvertently minimizing qualitative warnings regarding high developmental costs or architectural complexity.

c. Critical Evaluation and Analytical Justification

- **Evaluation:** Qualitative analysis proved highly unsuited for evaluating specific technical engineering criteria (e.g., memory heap allocation or byte-size throughput). Furthermore, while it provided incredibly rich and nuanced narratives regarding "Insider Threats," these thematic outcomes are inherently subjective, un-replicable, and heavily reliant on the specific psychological state of the four interviewees at the time of the discussion.
- **Justification:** Nevertheless, Qualitative Analysis was the vital "Reality Check" of the project. A system can be mathematically impenetrable, but if it is despised by developers or misunderstood by end-users, it will fail conceptually. Qualitative analysis justified the business value and ethical necessity of the project, proving that taking the power away from internal DBAs (via Application-Layer Encryption) directly answers the deepest privacy concerns of the modern E-commerce market.

3. Analytical Justification for the Selection of Research Methods

The core philosophy of this computing project is grounded in Mixed-Methods Triangulation. In the modern era of Cybersecurity, a security architecture cannot exist merely as abstract mathematical equations; it must intersect seamlessly with human experience and hardware limitations. The following section provides the analytical justification for why the synchronized integration of these specific methodologies (Primary, Secondary, Quantitative, Qualitative) was the optimal and only viable approach for this project.

3.1. Justifying the Combination of Primary and Secondary Research

- **The Role of Secondary Data (Mathematical and Regulatory Baseline):** A fundamental antipattern in Cybersecurity engineering is attempting to invent custom cryptographic algorithms ("rolling your own crypto"). Therefore, secondary data served as an absolute prerequisite. By actively adopting the National Institute of Standards and Technology specifications (NIST SP 800-38D for AES-256-GCM) and Cloud KMS whitepapers, the project was instantly anchored to enterprise-grade, peer-reviewed foundations. This eliminated the severe risk of introducing fundamental mathematical vulnerabilities into the EncryptionService.js module.
- **The Role of Primary Data (Localized Boundary Testing):** While theoretical documentation is structurally perfect, it cannot predict the volatile memory (RAM) consumption of a localized Node.js server during a decryption cycle, nor can it anticipate the system's autonomic response to an insider threat. Primary data (collected via JMeter stress testing and Red-Team "Bit-Flipping" simulations) illuminated these operational blind spots. Extracting proprietary telemetry (e.g., latency metrics) allowed the researcher to directly measure the resilience of the theoretical models when constrained to a lightweight architecture, thereby exposing critical real-world bottlenecks such as server overload during automated Key Rotation.

3.2. Justifying the Combination of Quantitative and Qualitative Analysis

- **Quantitative Analysis (Establishing Objective Red Lines):** Quantitative analysis injected "ruthless objectivity" into the project. The statistical consensus from 78 experts that transaction latency must remain under 50ms, combined with the empirical benchmark of 15-22ms, provided immutable mathematical constants. This method successfully eliminated subjective biases, establishing highly precise, non-negotiable Key Performance Indicators (KPIs) to measure algorithmic success.
- **Qualitative Analysis (Understanding Operational Friction and UX/UI):** If a High-Security system is too complex, internal staff and developers will inevitably attempt to bypass it. Qualitative analysis rescued the architecture from this dangerous rigidity. It was the explicit complaints extracted from developer interviews concerning "database blindness" (the inability to execute SQL SELECT queries on ciphertext) that directly inspired the "Hybrid Storage" architectural pivot—encrypting PII while retaining Metadata in plaintext for indexing. Furthermore, end-user feedback revealed that Application-Layer Encryption is not merely a defensive mechanism but a potent UX/UI marketing asset. Displaying "Zero-Trust Protected" badges on the frontend directly translates complex cryptography into profound consumer trust.

3.3. Synthesizing the Holistic View

Relying on any single methodology would have inherently generated a catastrophic architectural blind spot. Relying solely on Secondary/Quantitative data would have produced an algorithmically flawless encryption engine that was operationally unmaintainable by the development team. Conversely, relying

exclusively on Primary/Qualitative data would have resulted in a highly user-friendly application fundamentally vulnerable to cryptographic brute-force attacks due to non-standardized ciphers.
The concurrent triangulation of these four methods constituted the final architectural keystone. This comprehensive strategy equipped the project with a "Holistic View," enabling the researcher to discover the ultimate *Sweet Spot*—a delicate, highly optimized equilibrium balancing Absolute Security, Elite Performance, and Seamless Usability within the Secure SCMS ecosystem.

X: Evaluate outcomes and make valid, justified recommendations

1. Evaluation of Achieved Outcomes

This section critically examines the actual results generated by the "Secure Supply Chain Management System" (SCMS) against the initial hypotheses and benchmarks established in the research proposal.

1.1. Synthesis and Presentation of Results

- Quantitative Metrics (Performance and Integrity): Unlike traditional Machine Learning models evaluated via ROC-AUC or F1-scores, the success of this cryptographic architecture was measured through distinct execution telemetry.

- **Latency Overhead:** The empirical JMeter load-testing recorded an algorithmic latency overhead of precisely 15ms - 22ms per transaction on the Node.js event loop. This dramatically outperformed the highly rigid benchmark of <50ms demanded by 75.6% of the surveyed industry professionals.
- **Cryptographic Integrity** *(Tamper Detection):* Through the simulated "Bit-Flipping" Red-Team attack injected directly into the SQL Server database, the AES-256-GCM authentication tag successfully intercepted unauthorized modifications, achieving a 100% anomaly detection rate. The system autonomously threw a cryptographic exception, effectively blocking fraudulent transactions.
- **Data Obfuscation Rate***:* 100% of defined Personally Identifiable Information (PII) and sensitive supply costs were successfully encrypted into AES-256 ciphertext prior to database insertion.

- Qualitative Results (UX/UI and Expert Feedback):

- **Positive Feedback:** Logistics experts validated that shielding wholesale pricing and exact vendor coordinates behind Application-Layer Encryption successfully neutralized the risk of corporate espionage by internal Database Administrators (DBAs). End-users reported that the frontend latency was imperceptible, and visually displaying "Zero-Trust Protected" badges significantly boosted platform confidence.
- **Negative/Friction Feedback***:* The software development team reported intense debugging friction during initial implementation. The inability to execute native SELECT * WHERE queries on the encrypted database payloads drastically slowed down the quality assurance (QA) pipeline, confirming the anticipated "Database Blindness" vulnerability.

1.2. Evaluation of Research Objectives Fulfillment To scientifically assess the project's success, each core objective is evaluated individually:

- **Objective 1 (Security - Neutralize Insider Threats via Zero Trust): FULLY COMPLETED.**
  - *Evaluation:* The project successfully revoked the raw data read privileges of DBAs. By executing the Envelope Encryption logic exclusively within the Application Tier (Node.js), the database acts solely as "blind storage." This effectively neutralizes lateral movement threats and internal data exfiltration.
- **Objective 2 (Processing Performance - Validate Under 50ms Latency): FULLY COMPLETED.**
  - *Evaluation:* The project achieved a stunning 15-22ms cryptographic penalty. This proves the hypothesis that executing AES-256-GCM at the Application Layer, when optimally engineered using native Node.js Crypto C++ bindings, does not degrade the E-commerce shopping experience or violate User Experience (UX) SLAs.
- **Objective 3 (Operation & Scalability - Deploy Self-managed Key Lifecycle): PARTIALLY COMPLETED.**
  - *Evaluation:* The architecture successfully eliminated "Vendor Lock-in" by constructing a custom Key Encryption Key (KEK) and Data Encryption Key (DEK) hierarchy. However, the system failed critically in scalability during the "Automated Key Rotation" objective.
  - *Limitation Exposing:* The codebase lacked a Key Versioning mechanism. Consequently, attempting to rotate the Master Key required the server to simultaneously pull, decrypt, and re-encrypt millions of legacy records into RAM, resulting in severe heap memory exhaustion and potential system downtime.

1.3. Root Cause Analysis of Anomalies and Performance Friction Understanding the factors that influenced these outcomes is vital for future iterations:

- **Hardware Instruction Sets (Positive Cause):** The outperformance in latency (15ms vs. 50ms) was not solely due to optimized JavaScript code. The root cause was the implicit utilization of AES-NI (Advanced Encryption Standard New Instructions) hardware acceleration embedded within modern CPUs, which allowed the cryptographic stream to execute in micro-seconds at the hardware level.
- **Architectural Rigidity (Negative Cause):** The primary cause behind the partial failure of Objective 3 (Key Lifecycle) was a monolithic architectural paradigm. The Node.js server was forced to handle routing, inventory logic, and massive cryptographic re-encryptions simultaneously. The single-threaded nature of Node.js proved inadequate for the CPU-bound task of bulk database re-encryption.
- **Data Fidelity vs. Searchability Trade-off:** The developer friction regarding "database blindness" stems directly from the implementation of randomized Initialization Vectors (IVs) for every ciphertext payload (ensuring semantic security). While this mathematically prevents pattern recognition attacks, it entirely shatters the relational database's capability to index or filter data natively.

2. Valid and Justified Recommendations for Future Architecture

Based on the critical evaluation of the SCMS execution metrics, structural bottlenecks, and the feedback extracted from the mixed-methods analysis, the following structural enhancements are heavily recommended to elevate the application from a localized prototype to an enterprise-grade Zero Trust ecosystem.

2.1. Optimization of the Cryptographic Engine and Cybersecurity Models

- **Implementation of "Key Versioning" Architecture:** To resolve the critical RAM exhaustion caused by rotating the monolithic Master Key, the architectural schema must be refactored. The database payload should be prepended with a Cryptographic Key Identifier (e.g., [Key-v2]-IV-AuthTag-Ciphertext). This allows legacy records to decrypt passively via deprecated keys, while new transactions utilize the active rotated key. This entirely neutralizes the high-risk necessity of executing an instant, bulk database re-encryption.
- **Homomorphic Encryption Exploration (Searchable Ciphertexts):** The primary developer friction point—Database Blindness—must be mitigated. Future cryptographic iterations should attempt to integrate emerging schemes like Fully Homomorphic Encryption (FHE) or advanced Blind Indexing algorithms. This would theoretically empower developers to execute functional LIKE querying or fuzzy clustering directly upon AES-256 ciphertexts without exposing the raw plaintext values, drastically improving DevOps debugging workflows.

2.2. Augmentation and Integrity Validation of Input Telemetry

- **Synthetic Data Augmentation and Adversarial Structuring:** The system was validated against a relatively homogenous dataset. To strictly validate the AES-256-GCM authentication threshold against advanced, polymorphic SQL Injection scenarios, the system should structurally integrate Data Augmentation mechanisms. By auto-generating an intense array of diverse, anomalous, and syntactically malformed supplier logistics telemetry, the resilience of the Encryption Service can be comprehensively stress-tested, actively exposing edge-case bias or parsing vulnerabilities in the Data Tier.
- **Audit Log Sanitization and Noise Filtration:** Security analytics depend heavily on clean telemetry. Currently, the audit_logs table absorbs vast amounts of routine authentication noise alongside critical tamper-detection exceptions. Deep-cleaning this dataset and extracting routine operational clutter is necessary to allow Security Operations (SecOps) personnel to definitively isolate the true statistical footprint of malicious lateral movement.

2.3. Architectural Refactoring and Performance Scaling

- **Strangler Fig Pattern (Event-Driven Microservices):** Implementing the highly intensive AES-256 Envelope Cryptography on a single-threaded Node.js event loop creates a systemic Single Point of Failure (SPOF). The cryptography logic (EncryptionService.js) must be decoupled from the core Express API via the Strangler Fig pattern. Relocating these CPU-bound tasks into a highly

concurrent Go (Golang) or Rust microservice—communicating via low-latency Protobuf buffers (gRPC)—would exponentially accelerate throughput.

- **Hardware Security Module (HSM) Cloud Migration:** Storing the Master Key in standard environment variables (.env) inherently caps the project at SME-grade security. A critical recommendation is to deploy a localized, containerized Key Management Service (such as HashiCorp Vault) or permanently migrate the key payload securely to Cloud-Native HSM perimeters (e.g., AWS KMS / Azure Key Vault).

2.4. Revolutionizing User Experience (UX/UI) within Security Thresholds

- **Contextual Friction and AI Interactivity:** Security systems often inherently degrade the User Experience. Expanding the application's intelligence via AI-driven Threat Profiling is recommended. If the Artificial Intelligence logic detects a routine, low-risk logistics access attempt from a recognized IP, it should minimize UI friction (e.g., bypassing strict MFA). Conversely, anomalous supply chain mutations should trigger dynamic, contextual re-authentication prompts on the frontend.
- **A/B Testing of Cryptographic Transparency:** End-user sentiment indicated a radical increase in trust when "Zero-Trust" principles were explicitly advertised. The UX/UI pipeline must implement severe A/B multivariate testing: Variant A displays standard E-commerce product logs, while Variant B dynamically displays "End-to-End Encrypted via AES-256." Measuring conversion rate disparities across these variants will mathematically quantify the exact commercial ROI of cryptographic transparency.

2.5. Strategic Trajectory for Future Academic Research

- **Post-Quantum Cryptography (PQC) Readiness:** While AES-256 is currently considered mathematically impenetrable by classical computational architecture, the impending commercialization of Quantum Computing (e.g., Shor's Algorithm) fundamentally threatens symmetric block ciphers. Future computing research projects (Level 6 and beyond) must dedicate rigorous empirical validation toward evaluating quantum-resistant cryptographic primitives (e.g., Lattice-based cryptography) and mathematically measuring their latency impact when integrated into the existing SCMS Application Layer.

Part 2

I. Discuss the effectiveness of research methods applied, for meeting objectives of the computing research project.

1. Introduction

To ensure the Secure Supply Chain Management System (SCMS) is not only technically robust but also effectively addresses real-world architectural vulnerabilities, the research employed a Mixed-Methods Research Strategy. By combining theoretical analysis (Secondary Research) with empirical benchmarking

and adversarial simulation (Primary Research), the project was evaluated from both a cryptographic security perspective and a high-performance operational perspective.

a. Restatement of Research Objectives:

The evaluation of methods is guided by three core cybersecurity objectives established at the project's inception:

- **Objective 1 (Security & Integrity):** To prevent 100% of "Insider Threats" by revoking raw data read privileges of Database Administrators (DBAs) through Application-Layer Encryption.
- **Objective 2 (Processing Performance):** To ensure the cryptographic overhead remains strictly under 50ms per transaction to maintain a seamless User Experience (UX).
- **Objective 3 (Operation & Scalability):** To build a self-managed cryptographic key lifecycle using Envelope Encryption to eliminate reliance on third-party Cloud KMS providers.

b. Overview of Applied Research Methods:

The project applied two complementary approaches to achieve these objectives:

- **Secondary Research (Mathematical Foundation & Standards):** Data was analyzed from international standards (NIST) and enterprise whitepapers (AWS) to architect the hierarchical key separation (KEK/DEK).
- **Primary Research (Empirical Validation):** Original evidence was generated to validate the implementation against performance and security requirements.
    - **Quantitative Methods:** A technical survey of **78 IT professionals** was conducted to establish industry benchmarks for acceptable latency and security risks.
    - **Qualitative Methods:** In-depth interviews with four stakeholders (IT Lecturer, Developer, Logistics Expert, End-user) provided insights into "Database Blindness" and consumer trust.

2. List of Specific Methods & Implementation

Each method was selected to address a distinct aspect of the cryptographic system development lifecycle.

a. Secondary Research (Literature Review):

- **Specific Sources:** The project analyzed NIST Special Publication 800-38D for AES-256-GCM specifications and OWASP Top 10 API Security Risks for threat modeling.
- **Implementation:** Used keywords such as "Envelope Encryption," "Authenticated Encryption (AEAD)," and "Zero Trust Architecture" to filter credible academic sources that informed the EncryptionService.js infrastructure.

b. Survey (Quantitative Data Collection):

- **Design:** A specialized survey was distributed to a highly technical audience to collect robust data on industry perceptions of insider threats and performance taxes.
- **Implementation:** Collected **78 valid responses** from specialists in Cybersecurity (39.7%), DBAs (30.8%), and DevOps (17.9%), establishing that 75.6% of the industry demands latency under 50ms.

c. In-depth Interview (Qualitative Insight):

- **Subject:** Interviews with four diverse subjects, including an academic expert (Ha Ngoc Linh) and a domain expert (Huong Giang).
- **Implementation:** Discussions focused on implementation pitfalls, such as the difficulty of debugging encrypted fields and the operational consequences of unauthorized plaintext access to supplier pricing.

d. Experiment / Lab (System Benchmarking & Testing):

- **Environment:** Conducted rigorous quantitative load testing via JMeter and Red-Team bit-flipping simulations within a local development sandbox.
- **Implementation:**
  - **Performance:** Injected 5,000 requests/minute to quantify the "Security Tax" of AES-256-GCM.
  - **Security:** Simulated a "Database Dump" and manual ciphertext mutation to test autonomic tamper detection.

3. Evaluation of the Effectiveness of Applied Research Methods

a. Relevance (System Security and Protection):

- **Assessment:** The Red-Team Simulation and Secondary Research were highly relevant for answering whether the architecture could independently reject unauthorized modifications without DBA intervention.
- **Evidence:** The system achieved a 100% anomaly detection rate; any manual bit-flipping in the SQL Server resulted in an Auth Tag Verification Failed exception.
- **Project Link:** This proves the "Blind Storage" model effectively achieved Objective 1 by mathematically decoupling data from the storage engine's security context.

b. Evidence Generation (Performance Benchmarking):

- **Assessment:** The JMeter Benchmarking generated precise telemetry that could not be extrapolated from theory alone.
- **Evidence:** Actual processing speed was recorded at 15ms–22ms per transaction, significantly outperforming the 50ms benchmark.
- **Project Link:** This provided irrefutable proof for the Assessment Board that Objective 2 was met without violating User Experience SLAs.

c. Reliability and Validity (System Integrity):

- **Reliability:** The consistency between the 78-expert survey results (ranking insider threats as high risk) and the Academic Interview (supporting Application-Layer Encryption) provided a stable foundation for the Zero-Trust implementation.
- **Validity:** The use of real-world cryptographic artifacts (IV, AuthTag, Ciphertext) and captured Node.js stack traces during testing made the results more valid than a purely theoretical paper model.

d. Ethical and Legal Considerations:

- **Privacy:** The primary research exclusively utilized synthetic dummy data (generated via add-dummy-partners.js), ensuring zero risk to real-world customer PII.
- **Anonymity:** Telemetry data consisted of hexadecimal strings and timestamps, fulfilling all ethics requirements for research anonymity.

e. Limitations and Bias:

- **Localhost Paradox:** Performance data was constrained to a local environment, which cannot perfectly replicate the chaos of wide-area networks or network jitter.
- **Researcher Bias:** The survey design carried a latent risk of confirmation bias, potentially framing questions to highlight the flaws of TDE to favor the proposed solution.

4. Illustrative Example: Deciding the "Hybrid Storage" Strategy

To illustrate how methods were combined to make a critical technical decision regarding storage architecture:

- **Step 1:** User Insight (Survey/Interview – Qualitative): Interviews revealed a "debugging nightmare" where developers go "blind" because they cannot run simple SELECT queries on fully encrypted tables.
- **Step 2:** Technical Evidence (Benchmarking – Quantitative): JMeter testing showed that while encryption is fast, querying unstructured multi-part cryptographic envelopes slows down database indexing.
- **Step 3:** Synthesis & Decision (Mixed-Methods Outcome): By triangulating the 29.9% survey support for a "Security-Performance compromise" with developer complaints, the project adopted a Hybrid Storage Schema.
    - **Result:** Metadata (Status, Timestamps) remains in plaintext for indexing, while PII (Pricing, Coordinates) is wrapped in Envelope Encryption, solving the "Database Blindness" issue.

5. Conclusion

Adopting a Mixed-Methods approach was the only viable strategy to balance Absolute Security, Elite Performance, and Seamless Usability.

- **Effectiveness:** Primary Research proved that the 15–22ms latency was technically feasible , while **Secondary Research** ensured the system followed globally vetted foundations (NIST) rather than "rolling its own crypto".
- **Limitations to Address:** The partial failure of Objective 3 (RAM exhaustion during Key Rotation) was a critical discovery that only primary stress testing could reveal, which was not predicted by secondary literature.
- **Future Improvement:** Future iterations must move from a monolithic Node.js event loop to a Go/Rust microservice to handle CPU-bound re-encryption tasks without degrading system stability.

II. Discuss alternative research methodologies and lessons learnt in view of the outcomes.

1. Introduction

The successful validation of the Secure Supply Chain Management System (SCMS) was predicated on a Mixed-Methods Research Strategy. By integrating Secondary Research (NIST standards) with Primary Research (JMeter benchmarks and a 78-expert survey), the project successfully proved that an application-layer AES-256-GCM architecture could achieve a microscopic latency of 15ms–22ms while maintaining 100% data integrity.

While these methods were effective for the scope of an academic computing project, this section explores alternative methodologies that could offer deeper verification for commercial-grade iterations and reflects on the critical lessons learned from the experimental data.

2. Possible Alternative Research Methodologies

Several alternative approaches were evaluated but ultimately excluded due to constraints on time, resources, and technical complexity.

Alternative Methodology	Description & Application	Merits (Pros)	Limitations (Cons)	Justification for Exclusion
1. Formal Verification	Using mathematical logic (e.g., TLA+) to prove the correctness of the AES-GCM state machine.	Provides 100% mathematical certainty that the encryption logic contains no logical flaws.	Extremely steep learning curve; outside the scope of standard software engineering timelines.	**Complexity:** The project prioritized empirical benchmarking via JMeter over abstract mathematical proofs to ensure practical viability.
2. Longitudinal Behavioral Study	Tracking warehouse staff for 6+ months to measure "Security Fatigue" related to the Hybrid Storage model.	Captures long-term shifts in user trust and identifies if staff attempt to bypass security measures.	Requires a duration significantly longer than a single academic semester.	**Timeline:** The project was constrained by a strict 12-week implementation roadmap.
3. External Red Team Exercise	Hiring independent security consultants to attempt a "Zero-Knowledge" breach of the SCMS.	Eliminates researcher bias and identifies edge-case vulnerabilities (e.g., Side-Channel attacks).	High financial cost; requires a production-ready cloud environment.	**Resources:** The research was conducted in a Localhost Sandbox to maintain zero-cost and 100% control .

3. Comparison and Justification: When to Use Alternative Methods?

While the applied methods (Survey, Benchmarking, POC) provided the "Backbone of Proof," the shift to alternative methods would be required if the project moves toward enterprise-scale deployment.

- **From Survey to Big Data Analysis:** The current **78-expert survey** established industry demand. However, for a global rollout, **Big Data Analysis** of real-time server logs across multiple geographic regions would be needed to account for **WAN Network Jitter**, which local testing cannot simulate .
- **From Red-Teaming to Automated Vulnerability Scanning:** My manual **Bit-Flipping simulations** proved autonomic detection . However, to meet commercial compliance (e.g., PCI-DSS), continuous **Automated Security Scanning** would be necessary to detect new $Zero-Day$ vulnerabilities in the Node.js dependencies.

4. Lessons Learnt

The research process yielded three profound technical and philosophical lessons that redefined the project's final recommendations.

a. The Conflict Between Data Fidelity and Searchability

Lesson: Absolute security can lead to "Operational Fallacy."

Initially, the project hypothesized that encrypting every data field was the superior posture. However, primary feedback from developers revealed that total encryption rendered the SQL Server "blind," making debugging and indexing impossible . This led to the **"Hybrid Storage"** pivot, teaching that security must be **Context-Aware** rather than monolithic .

b. Infrastructure Limits of Monolithic Architecture

Lesson: The single-threaded nature of Node.js is a bottleneck for CPU-bound cryptography.

During the **Automated Key Rotation** simulation, the system encountered severe **RAM exhaustion** . This outcome proved that while $AES-256$ is fast for single transactions (15ms), bulk re-encryption of millions of records requires a **Decoupled Microservices** architecture (e.g., Go or Rust) to prevent system downtime .

c. Security as a Psychological Asset

Lesson: Transparency builds more trust than the encryption algorithm itself.

The **End-User Interviews** revealed a significant "Privacy Anomaly": users were anxious about PII but didn't understand how it was protected . This taught the team that backend $AES-256$ must be paired with **Frontend Trust Indicators** (e.g., "Zero-Trust Protected" badges) to translate technical security into a commercial competitive advantage .

5. Conclusion

Adopting a **Mixed-Methods Approach** was the most effective strategy for the SCMS project given the academic constraints. It allowed for the discovery of a **"Sweet Spot"**—a delicate equilibrium balancing

Absolute Security (100% integrity) with **Elite Performance (15ms–22ms latency)**. The alternative methods discussed above provide a clear strategic roadmap for transitioning this academic prototype into a resilient, enterprise-grade Zero-Trust ecosystem.

III. Analyse results in recommended actions for improvements and future research considerations.

1. Summary of Key Findings

Based on the mixed-methods research process involving a 78-participant technical survey , stakeholder interviews , and JMeter load testing, the following critical findings have been identified:

- **Finding 1: Performance Success vs. Operational Failure:** While the system achieved an elite latency of **15ms - 22ms** , significantly outperforming the industry benchmark of <50ms , it faced a critical failure in memory stability during automated key rotation simulations .
- **Finding 2: Overwhelming Demand for Zero Trust:** 59% of IT experts perceive insider threats as a high or critical risk , and 83% of respondents demand that sensitive data be encrypted before database storage.
- **Finding 3: The "Database Blindness" Paradox:** Qualitative interviews revealed that while $AES-256-GCM$ ensures 100% integrity , the use of randomized Initialization Vectors (IVs) makes native SQL indexing and debugging impossible for developers .
- **Finding 4: Fear of Vendor Lock-in:** 43.6% of surveyed experts identified "Vendor Lock-in" as the primary barrier to adopting Cloud KMS , justifying the project's decision to build a localized, custom envelope encryption module.

2. Cause & Effect Analysis

The research team analyzed the root causes of the identified anomalies to determine their potential consequences for an enterprise-grade rollout.

- Issue: Severe RAM Exhaustion during Key Rotation
    - **Root Cause:** A monolithic architectural paradigm where the Node.js event loop is forced to pull, decrypt, and re-encrypt millions of records simultaneously .
    - **Consequence:** Potential system downtime and data corruption if a rotation is triggered during peak warehouse operational hours.
- Issue: Reduced Quality Assurance (QA) Speed
    - **Root Cause:** Semantic security requirements (random IVs) prevent developers from executing simple SELECT * WHERE queries on ciphertexts .
    - **Consequence:** Increased development costs and longer debugging cycles, which may lead staff to bypass security protocols to save time.
- Issue: Security-Usage Gap

- **Root Cause:** A lack of frontend visibility regarding backend encryption. Users feel anxious about data privacy because the protection is "invisible".
- **Consequence:** Lower platform adoption rates and reduced competitive advantage despite having "banking-grade" security.

3. Recommended Actions

To transition the SCMS from an academic prototype to a resilient ecosystem, the following actions are proposed:

a. Technical Architecture (Integrity & Scalability)

- **Action 1: Implement "Key Versioning" Architecture:** Prepend database payloads with a Key ID (e.g., [Key-v2]) . This allows legacy data to decrypt passively using older keys while new data uses the rotated key, eliminating bulk re-encryption RAM spikes .
- **Action 2: Decouple Cryptography via Strangler Fig Pattern:** Move the EncryptionService.js logic into a high-concurrency **Go or Rust microservice** . This offloads CPU-bound tasks from the main Node.js thread, exponentially increasing transaction throughput.

b. Governance & Policy (Privacy Control)

- **Action 3: Hardware Security Module (HSM) Migration:** Move the Master Key (KEK) from standard .env variables to a dedicated secret manager like **HashiCorp Vault** or **AWS KMS** to satisfy professional standards for high-stakes financial data.

c. People & UX (Trust Optimization)

- **Action 4: Deploy Visual Trust Indicators:** Integrate "Zero-Trust Protected" badges and color-coded risk alerts on the frontend. This translates complex cryptography into psychological confidence for the non-technical demographic.

4. Priorities & Development Roadmap

Based on the **57% user retention threat** identified in the research, the following roadmap is prioritized:

1. **Phase 1 (Urgent - 0-3 Months):** Patch the RAM bottleneck using **Key Versioning** and implement **Input Sanitization** to prevent SQLi-driven tag failures .
2. **Phase 2 (Optimization - 3-6 Months):** Transition to **Hybrid Storage** as the default standard and upgrade the UI to include **Trust Badges**.
3. **Phase 3 (Expansion - 6-12 Months):** Decouple to **Rust-based microservices** and conduct external **Red-Team penetration testing** to validate the system against real-world adversarial lateral movement.

5. Proposed Metrics (Key Performance Indicators)

The following KPIs will measure the success of the recommended improvements:

Metric / KPI	Target Value	Strategic Relevance
Cryptographic Latency	< 25ms	Ensures security remains invisible to the end-user.
Tamper Detection Rate	100%	Maintains the "Source of Truth" for critical logistics pricing.
Rotation Memory Spike	< 10% RAM	Prevents server crashes during master key lifecycle events.
Searchability Index	> 90%	Measures the effectiveness of Hybrid Storage in allowing developer queries.

6. Future Research Directions

To remain at the forefront of secure logistics, the project identifies three future research avenues:

- **Fully Homomorphic Encryption (FHE):** Investigate FHE to allow fuzzy clustering and LIKE queries directly on ciphertexts, finally solving the "Database Blindness" paradox .
- **Post-Quantum Cryptography (PQC):** Evaluate lattice-based cryptographic primitives to protect SCMS telemetry against future quantum attacks (e.g., Shor's Algorithm) .
- **AI-Driven Threat Profiling:** Use machine learning to monitor audit logs for anomalous lateral movement, moving beyond static heuristic rules.

7. Conclusion

Through the analysis of the **15% performance trade-off** against the **83% user demand for encryption**, this research has moved beyond theoretical assumptions to provide a validated security framework. The recommended transition to **Key Versioning** and **Microservices** will ensure that the SCMS achieves enterprise-grade resilience while establishing absolute consumer trust as a competitive advantage.

IV. Reflection and Engagement in the Research Process

1. Reflection on the Research Journey

a. Evolution of the Initial Idea

At the project's inception, my hypothesis was technically idealistic: I believed that implementing a monolithic application-layer encryption model using AES-256-GCM would solve all security vulnerabilities without operational drawbacks. I initially assumed that "more encryption is always better."

However, through the research process, this idea evolved from a purely mathematical goal to a pragmatic architectural balance. Secondary research into NIST SP 800-38D standards taught me that integrity (authentication tags) is as vital as confidentiality. Simultaneously, primary benchmarking with JMeter revealed that while encryption was fast (15ms–22ms), the "Database Blindness" caused by full encryption created a significant developer friction point that I had not originally anticipated.

b. What Went Well (Successes)

- **Performance Optimization:** One of the most significant successes was achieving a latency overhead far below my 50ms benchmark. Leveraging **AES-NI hardware acceleration** instructions proved that high-level security does not have to compromise user experience.
- **Empirical Validation:** The **Red-Teaming** bit-flipping simulation provided incontrovertible evidence of the system's "Self-Immunology". Seeing the system autonomously reject tampered data confirmed that the Zero-Trust architecture was functional, not just theoretical.

c. What Could Be Done Better (Areas for Improvement)

- **Scalability Planning:** My initial roadmap underestimated the complexity of **Automated Key Rotation**. Facing a memory overload during simulation was a humbling lesson in the limitations of single-threaded environments like Node.js for CPU-bound cryptographic tasks.
- **Sample Diversity:** While I engaged **78 technical experts**, the sample was heavily skewed toward DBAs and Security Experts . Including more Frontend UX engineers in the survey might have yielded more nuanced data on the psychological impact of security indicators on the average shopper.

2. Engagement with Resources & Stakeholders

a. Interaction with Knowledge Sources (Resources)

I maintained a high standard of academic ethics by prioritizing authoritative, peer-reviewed sources over community tutorials:

- **Official Standards:** I engaged deeply with NIST Special Publication 800-38D to ensure the **EncryptionService.js** module correctly handled Galois/Counter Mode requirements.
- **Enterprise Architecture:** Analyzing AWS KMS whitepapers allowed me to synthesize a professional key hierarchy (KEK/DEK) that elevates the project beyond a simple student application.

b. Approach to Stakeholders (People)

- **Academic Supervision:** Regular consultations with my IT Lecturer (**Ha Ngoc Linh**) provided the architectural critique needed to justify the shift from TDE to ALE . Her warnings about key lifecycle management directly led to my focus on rotation strategies.
- **Domain Expert Engagement:** Interviewing **Huong Giang** (Logistics Expert) was crucial in identifying that wholesale vendor pricing was the "Crown Jewel" of the data, requiring the strictest tamper detection to prevent corporate espionage.

3. Impact of Engagement on Results & Recommendations

My active engagement with stakeholders and empirical data forced two major "pivots" in the project:

- **The Hybrid Storage Pivot:** Originally, I planned to encrypt the entire database. However, developer feedback regarding the inability to perform SELECT queries on ciphertext led me to adopt a **Hybrid Storage Strategy**. This decision successfully balanced high-speed indexing for metadata with banking-grade protection for PII.

- **The Key Versioning Recommendation:** The engagement with the **JMeter** performance logs during rotation failure led to my most significant future recommendation: **Cryptographic Key Versioning**. This architectural shift ensures system stability and addresses the RAM bottleneck identified during testing.

4. Reflection on Resource Use & Reliability

I evaluated my sources based on a hierarchy of reliability to ensure system integrity:

Source Type	Specific Example	Reliability Rating	Critical Reflection
Official Standards	NIST SP 800-38D	High (Gold Standard)	Provided the non-negotiable mathematical baseline for AES-GCM integrity.
Industry Intelligence	OWASP Top 10	High	Essential for identifying Broken Object Level Authorization as a primary threat.
Primary Telemetry	JMeter Latency Logs	High	Most reliable evidence for proving the 15ms–22ms performance tax.
Technical Surveys	78-Participant Data	Medium-High	Highly reliable for technical thresholds but carries a latent risk of respondent bias.

5. Actions for Future Process Improvement

Based on the lessons learned, I propose the following actions to improve the research and implementation process for future SCMS iterations:

- **Standardize Security Benchmarking:** I will implement automated **Sentry** logging and **Postman** monitoring to aggregate latency data more efficiently, reducing the time spent on manual JMeter log analysis.
- **Decouple Architectural Components:** To resolve the RAM spikes identified during this project, I will shift to an **Event-Driven Microservices** model (Strangler Fig pattern), moving cryptography to a Rust or Go service to better utilize multi-core hardware .
- **Early Red-Teaming:** In future projects, I will integrate **SAST (Static Application Security Testing)** tools earlier in the development roadmap to identify "Implementation Gaps" before the final benchmarking phase.

6. Conclusion

The research journey for the SCMS project has been a transformative experience. By moving beyond a "Technical Tunnel Vision" to engage with the psychological and operational realities of cybersecurity, I have developed a system that is not only mathematically secure but also practically viable. The challenges faced—specifically the RAM bottlenecks—have not been failures, but rather critical data points that have informed a more resilient, enterprise-ready future architecture.

C. Conclusion

The research project, *"Encrypting Order Transaction Information for an E-commerce Program,"* commenced with a critical proposition: the traditional reliance on database-level security perimeters—specifically Transparent Data Encryption (TDE)—is fundamentally insufficient to protect sensitive supply chain logistics from internal espionage and advanced persistent threats. By transitioning from theoretical vulnerability analysis to the empirical engineering of the "Secure Supply Chain Management System" (SCMS), the project successfully formulated, implemented, and stressed-tested a definitive Zero Trust architecture.

Throughout its execution, the methodologies applied successfully validated all primary hypotheses. By systematically shifting the encryption logic to the Application Layer (Node.js) using the AES-256-GCM (Galois/Counter Mode) standard, the architecture definitively revoked the plaintext access privileges of Database Administrators (DBAs), forcing the SQL Server to function strictly as "blind storage" and neutralizing lateral data exfiltration attempts. Furthermore, the project advanced beyond mere data obfuscation to establish mathematical data immutability. As empirically proven through Red-Team "Bit-Flipping" simulations, the active validation of the GCM Authentication Tag operates as a real-time Internal Intrusion Detection System, successfully rejecting 100% of unauthorized database modifications. Crucially, by leveraging localized performance telemetry alongside an industry survey of 78 experts, the research empirically established that robust Envelope Encryption does not inherently degrade E-commerce throughput. By achieving a microscopic latency overhead of 15ms to 22ms per transaction, the prototype thoroughly surpassed the industry-standard benchmark constraint of 50ms, ensuring that intense cryptographic mathematics operates frictionlessly behind a seamless User Experience (UX).

However, the computing research process honestly revealed that establishing absolute security purely mathematically constitutes an operational fallacy. The qualitative friction recorded from developer interviews regarding "Database Blindness" exposed the severe operational risk of rendering massive relational databases entirely unsearchable. Consequently, the project's most significant architectural breakthrough was the conceptualization of the "Hybrid Storage Schema." By deliberately leaving non-sensitive metadata in plaintext while wrapping critical primitives in an encrypted blob, the architecture successfully solved the complex equation balancing total data privacy with high-speed indexing searchability. Nonetheless, while the system achieved exemplary throughput, significant scalability constraints within the monolithic Key Lifecycle Engine were identified. The vulnerability exposed during automated Master Key rotation—characterized by severe RAM exhaustion on the Node.js event loop—clearly dictates the immediate necessity for future iterations to integrate Cryptographic Key Versioning and decouple the encryption service into a dedicated, event-driven microservice.

In conclusion, this project transcends the development of a rudimentary web application; it represents a systematic synthesis of international cryptographic standards, primary threat intelligence, and empirical software engineering. By successfully engineering a localized Envelope Encryption architecture that prevents cloud vendor lock-in while matching enterprise-grade security logic, the "Secure SCMS" archetype proves that Small and Medium Enterprises (SMEs) can economically achieve profound data privacy. Ultimately, this research demonstrates that modern encryption should not be isolated as a mere defensive mechanism. By explicitly embedding "Zero-Trust Protected" indicators within the consumer frontend, the project successfully transforms stringent backend cryptography into a psychological asset, establishing absolute consumer trust as the highest competitive advantage in the future of E-commerce.

D. References

1. Amazon Web Services (AWS), (2023). *AWS Key Management Service Best Practices*. [online] Available at: https://docs.aws.amazon.com/kms/latest/developerguide/best-practices.html [Accessed 15 Jan. 2026].
2. Bace, R. and Mell, P. (2001). *NIST Special Publication on Intrusion Detection Systems*. [online] Dtic.mil. Available at: https://apps.dtic.mil/sti/html/tr/ADA393326/.
3. Google Books. (2017). *Research Design*. [online] Available at: https://books.google.com.vn/books?hl=vi&lr=&id=335ZDwAAQBAJ&oi=fnd&pg=PT16&dq=Creswell.
4. Dworkin, M.J., (2007). *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*. NIST Special Publication 800-38D. [online] Gaithersburg, MD: National Institute of Standards and Technology. Available at: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38d.pdf [Accessed 20 Jan. 2026].
5. Fowler, M., (2004). *Strangler Fig Application*. [online] MartinFowler.com. Available at: https://martinfowler.com/bliki/StranglerFigApplication.html [Accessed 10 Feb. 2026].
6. Rauf, I., Petre, M., Tun, T., Lopez, T., Lunn, P., Van Der Linden, D., Towse, J., Sharp, H., Levine, M., Rashid, A. and Nuseibeh, B. (2022). The Case for Adaptive Security Interventions. *ACM Transactions on Software Engineering and Methodology*, 31(1), pp.1–52. doi:https://doi.org/10.1145/3471930.
7. Node.js Foundation, (2024). *Crypto - Node.js v20.x Documentation*. [online] Available at: https://nodejs.org/api/crypto.html [Accessed 5 Feb. 2026].
8. OWASP Foundation, (2023). *OWASP Top 10 API Security Risks – 2023*. [online] Available at: https://owasp.org/API-Security/editions/2023/en/0x11-t10/ [Accessed 12 Jan. 2026].
9. Sherman, A.T., DeLatte, D., Neary, M., Oliva, L., Phatak, D., Scheponik, T., Herman, G.L. and Thompson, J. (2017). Cybersecurity: Exploring core concepts through six scenarios. *Cryptologia*, 42(4), pp.337–377. doi:https://doi.org/10.1080/01611194.2017.1362063.
10. Mehrban, A., Houda, Z.A.E., Moudoud, H. and Le, L.B. (2025). Integrating Zero Trust Architecture in O-RAN: A Comprehensive Survey and Analysis. *IEEE Open Journal of the Communications Society*, pp.1–1. doi:https://doi.org/10.1109/ojcoms.2025.3644132.

11. Google Books. (2026). *Threat Modeling*. [online] Available at: https://books.google.com.vn/books?hl=vi&lr=&id=YiHcAgAAQBAJ&oi=fnd&pg=PR21&dq=%E2%80%A2%09Shostack. [Accessed 1 Mar. 2026].
12. Stallings, W. (2024). Contribution of problems and exercises at end chapters plus book interactive online exercises MCQ In: Cryptography and Network Security: Principles and Practice, Global Edition, 8th edition. *Londonmet.ac.uk*. [online] . Available at: https://repository.londonmet.ac.uk/9653/

E. Project Resources